



OWASP
Smart Contract Security

scs.owasp.org

Security Handbook : Hiring, Remote Work, and Insider Threat

05

Security Handbook Series

GRANT SUPPORT • 2025-2026



ecosystem
support
program

Supported by Ethereum Foundation's
Ecosystem Support Program (ESP)



Contents

Frontispiece	4
About This Handbook	4
Copyright and License	5
Author and Creative Credits	5
Purpose and Scope	6
Target Audience	6
How to Use This Handbook	6
Relationship to SCSVS, SCSTG, and SCWE	7
Part I: Foundations	8
1. Introduction to Hiring and Remote Work Security	8
2. Threat Context: DPRK and Similar Vectors	11
Part II: Hiring Security	20
3. Job Posting and Sourcing	20
4. Interview and Assessment	21
5. Vendor and Contractor Selection	28
6. Background and Verification (Legal and Practical)	30
Part III: Remote Work and Overseas Consultation	33
7. Remote Work Security	33
8. Overseas Consultation and Distributed Teams	36
9. After Hire: Post-Hire Behavior and Monitoring	40
10. Ongoing Monitoring and Offboarding	43
11. Mitigating Insider Threat Actors	45
Part IV: Detection and Response	47
12. Recognizing Potential Compromise	47
13. Response Playbook: Suspected Insider or Compromised Hire	51
14. Response Playbook: Malware or Phishing Linked to Hire/Vendor	55
Part V: Hardening and Best Practices	59
15. Organizational Defenses	59
16. Training for Hiring Managers and HR	63
17. Policy Templates and Checklist	66
18. References to External Advisories and Resources	69

Part VI: Appendices	72
19. Appendix A: Glossary	72
20. Appendix B: Red Flags and Indicators (Summary)	76
21. Appendix C: Hiring and Vendor Security Checklist	80
22. Appendix D: References, Advisories, and Further Reading	83
Appendix C: References and Further Reading	84
Standards and Frameworks	84
Incidents and Case Studies	84
Tools and Documentation	85
Further Reading	86

Frontispiece

OWASP SMART CONTRACT SECURITY PROJECT

Hiring, Remote Work, and Insider Threat

About This Handbook

Hiring, Remote Work, and Insider Threat is part of the OWASP Smart Contract Security Handbook Series. The series extends smart contract security beyond contract code into the people, process, application, infrastructure, and operational layers surrounding Web3 systems.

Each handbook is designed as a defensive field reference for architects, engineers, security practitioners, incident responders, auditors, and organizational leaders. It complements the OWASP Smart Contract Security Verification Standard (SCSVS), Smart Contract Security Testing Guide (SCSTG), Smart Contract Weakness Enumeration (SCWE), Smart Contract Top 10, and SCS Checklist without replacing those resources.

SERIES EDITION **2026**

Copyright and License

Copyright © 2026 The OWASP Foundation and contributors.



This document is released under the [Creative Commons Attribution-ShareAlike 4.0 International License](#). You may share and adapt the material with appropriate attribution and under the same license. For reuse or distribution, make the license terms clear and identify material changes.

OWASP publications are community-developed educational resources. References to organizations, products, or services do not constitute endorsement, and the material is provided without warranty.

Author and Creative Credits

PROJECT LEAD

Shashank | CredShields

CEO and Co-Founder

AUTHOR | PROJECT MAINTAINER

Pratik Lagaskar

Security Researcher

COVER PAGE DESIGNS

Siddharth Neekher

Lead UI Designer @ CredShields

OWASP Smart Contract Security Project

Purpose and Scope

This handbook gives hiring, remote work, and vendor management guidance for Web3 and crypto-native organizations facing a specific and now well-documented threat: state-sponsored IT worker fraud. The guidance follows published advisories from the Federal Bureau of Investigation (FBI), the Cybersecurity and Infrastructure Security Agency (CISA), and the FBI's Internet Crime Complaint Center (IC3) describing how operatives linked to the Democratic People's Republic of Korea (DPRK) obtain remote developer and IT roles at Western companies, then use that access for data extortion, source code theft, credential harvesting, and sanctions-evasion revenue generation. The same infrastructure of fabricated identities, laptop farms, and complicit facilitators supports insider-threat actors beyond a single nation-state, so the controls here generalize past the DPRK case that motivates them.

The scope runs from the job posting to the exit interview and beyond it: recruitment channel hygiene, identity verification for remote hires, red flags visible during interviews and background checks, vendor and contractor due diligence, least-privilege access design for distributed teams, and the detection and response playbooks an organization needs once a hire is suspected of being compromised or malicious. It does not restate general operational security practice covered elsewhere in the series; it applies that practice to the specific moment a threat actor first receives a badge, a laptop, or a commit token.

Target Audience

HR and talent acquisition teams, security and IT leadership, hiring managers, and vendor management staff at Web3 and crypto-native organizations. The chapters split along these lines: HR and hiring managers own Parts II and III, security teams own Part IV, and leadership owns the policy and training work in Part V.

How to Use This Handbook

Read Part I first regardless of role: it sets the threat context that makes every later control legible, including how DPRK-linked IT workers operate and why their tactics differ from a typical fraudulent applicant. Hiring managers and HR staff working an active requisition should move to Parts II and III for the sourcing, interview, verification, and remote-onboarding controls that apply before and during a hire. Security and incident response staff should jump to Part IV when a hire is already suspected. Part V holds the policy templates and training material leadership needs to institutionalize the program, and Part VI collects the glossary, indicator summary, and checklist for quick reference during a live decision.

Relationship to SCSVS, SCSTG, and SCWE

This handbook sits upstream of the OWASP smart contract standards rather than inside them: its subject is the person who writes or reviews the code, not the code itself. The Smart Contract Security Verification Standard (SCSVS) and the Smart Contract Weakness Enumeration (SCWE) assume a codebase already exists to verify or catalog; the controls here reduce the odds that a hostile actor sits inside the team producing that codebase, a precondition neither standard otherwise addresses. The Smart Contract Security Testing Guide (SCSTG) tests what ships; nothing in that guide catches a developer who deliberately plants a vulnerability designed to pass every test. This handbook is closest in scope to the Employee Lifecycle Security Handbook (03), which owns onboarding, access provisioning, and offboarding mechanics once someone is hired, and the Incident Response Handbook (06), whose playbooks this handbook's Part IV extends for the specific case of a compromised or malicious hire.

Part I: Foundations

This part sets the vocabulary and threat model the rest of the handbook builds on: what makes hiring and vendor security a distinct control surface in Web3, and what the fraudulent-IT-worker threat tied to the Democratic People's Republic of Korea (DPRK) looks like in enough operational detail to recognize before a badge or a signer key is issued. It draws on U.S. law enforcement and Treasury advisories, threat-intelligence tracking of the specific actor cluster, and documented enforcement cases to ground the guidance that Parts II through VI turn into hiring, vendor, and monitoring controls.

1. Introduction to Hiring and Remote Work Security

Hiring is rarely modeled as an attack surface, yet in a Web3 organization it grants access that a phishing campaign or a dependency compromise would otherwise have to fight for. This chapter frames why that matters and how the handbook is organized to address it.

1.1 Why Hiring and Vendor Security Matter in Web3

Most Web3 organizations hire the way a five-person startup hires: fast, remote-first, and heavy on contractors sourced through Upwork, Toptal, referral chains, and Discord or Telegram job boards rather than a formal applicant-tracking process with a background-check vendor attached. That speed is a competitive necessity in a market where a smart contract team can go from funding to mainnet in weeks, but it collapses the friction that would otherwise slow a fraudulent applicant down: identity verification, reference checks, and a security team with the headcount to review who is being granted a multisig signer slot before the grant happens. A single senior engineering hire can, within weeks, end up holding a private key, a treasury multisig cosigner slot, or commit access to the contracts holding user funds. Nowhere else in mainstream software does one hiring decision route so directly to irreversible loss.

The Munchables incident makes the stakes concrete. In March 2024, the Blast-network game Munchables was drained of roughly \$62 million after an exploit traced to a backdoor in code written by a developer the team had employed for months under a pseudonym. On-chain

investigation, including work by the pseudonymous investigator [ZachXBT](#), linked the developer's wallet activity to the North Korean IT-worker cluster tracked across the industry; the funds were ultimately returned voluntarily rather than recovered by force, which is not something a defender can plan a control around. The lesson generalizes past this one project: a hiring decision is now a security decision with the same blast radius as a smart contract bug.

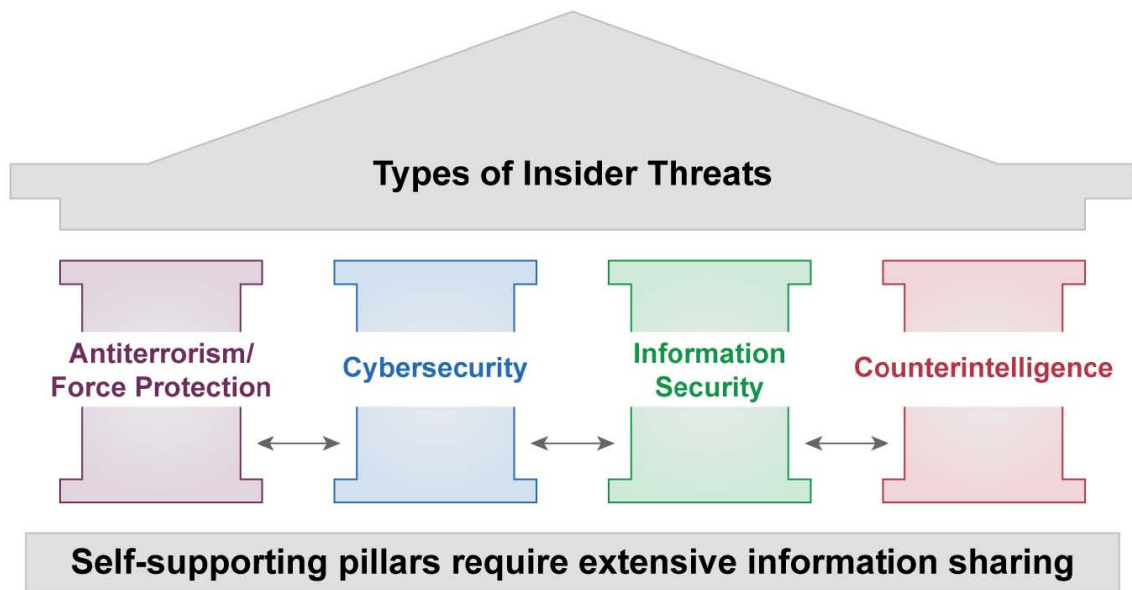
Vendor risk compounds this. Crypto-native firms routinely subcontract development, audit re-mediation, or IT support to overseas shops sourced through the same freelance marketplaces the direct-hire fraud exploits, so the threat does not stop at the org chart's edge. It extends through every staffing agency and dev shop holding a badge to your repository.

1.2 Insider Threat and Supply-of-Labor Risks

Insider threat is usually taught as two categories: the malicious insider who intends harm, and the negligent insider who causes harm by mistake. The DPRK IT-worker scheme adds a third category that traditional insider-threat programs are not built to catch: an insider whose entire identity, resume, and interview performance is fabricated from the start, so there is no "trusted employee turns bad" moment to detect. The malice is present on day one; only the access is missing, and hiring is the control that grants it.

Frame this as a supply-of-labor problem, parallel to the software supply chain covered elsewhere in this series. Just as a compromised npm package or a hijacked content delivery network (CDN) can inject attacker code into a product a team never wrote, a compromised hiring or staffing channel can inject an attacker directly into the team that writes the product. Each hop in the labor pipeline, a job board, a recruiter, a staffing agency, a freelance marketplace, a subcontracted dev shop, is a place where identity can be laundered the same way a malicious package launders itself through a registry.

Insider category	Intent	Typical access path	Example
State-sponsored operative	Deliberate from hire	Direct full-time or contract hire	DPRK IT worker under fabricated identity
Financially coerced insider	Acquired after hire	Existing legitimate employee	Extortion following termination
Witting facilitator	Deliberate, non-technical role	Domestic proxy for overseas operative	"Laptop farm" operator
Unwitting facilitator	None (victim of a separate scam)	Believes role is legitimate remote work	Recruited via fake "package reshipping" job
Ordinary negligent insider	None	Legitimate employee, poor judgment	Credential reuse, phishing victim



Source: GAO analysis of Department of Defense (DOD) information. | GAO-15-544

Figure. A U.S. Government Accountability Office graphic breaking down the threat categories a mature insider-threat program has to cover; the DPRK IT worker case in the table above is the state-sponsored-operative slice of this broader taxonomy. Source: U.S. GAO, GAO-15-544, public domain (U.S. federal government work).

Figure 10. Factors Along the Critical Path to Insider Risk

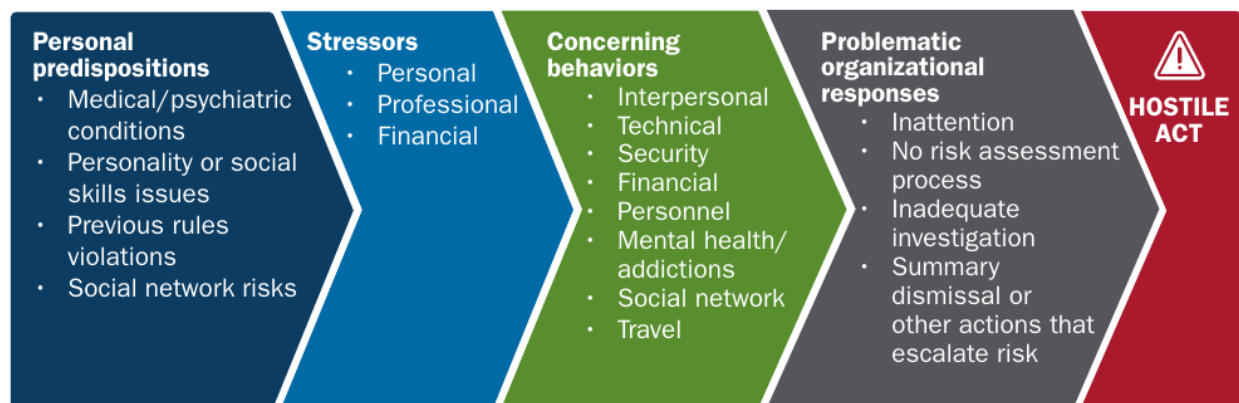


Figure. CISA's critical-path model prevents two dangerous simplifications: treating one unusual behavior as proof, and treating insider risk as a trait of one person alone. The path combines personal context, observable stressors, behavior, and the organization's own response; controls should interrupt the path without turning a risk model into discriminatory profiling. Source: CISA Insider Threat Mitigation Guide, Figure 10, public domain (U.S. government work).

1.3 Relationship to OpSec and Employee Lifecycle

This handbook sits between two others in the series and depends on both. The Web3 Operational Security Handbook (11) covers the day-to-day hygiene a legitimate team member is expected to practice once hired: key management, secure communications, device hardening. None of that matters if the person practicing it was never legitimate to begin with; this handbook's controls run earlier in the timeline, at the moment an organization decides who becomes a team member in the first place. The Employee Lifecycle Security Handbook (03) owns the mechanics of onboarding, access provisioning, role changes, and offboarding once a hiring decision is made. This

handbook is the filter upstream of that lifecycle: its Parts II and III determine whether Handbook 03's onboarding process should ever begin for a given candidate, and its Part III feeds ongoing-monitoring signals back into the offboarding process Handbook 03 defines. Part IV extends the Incident Response Handbook (06) with playbooks specific to a compromised or malicious hire, a scenario general incident-response runbooks rarely enumerate explicitly. Read narrowly, this handbook answers a question the smart-contract-focused OWASP standards do not: before you verify the code against the Smart Contract Security Verification Standard (SCSVS) or catalog its weaknesses against the Smart Contract Weakness Enumeration (SCWE), do you know who wrote it?

1.4 How to Use This Handbook

Read this Part in full regardless of role; the threat context in Chapter 2 is the foundation every later control assumes. From there, the handbook splits by function. HR and talent-acquisition staff working an open requisition move to Part II for job-posting hygiene, interview design, vendor selection, and verification practices to apply before an offer goes out. Hiring managers should read Part II alongside HR, since several red flags surface only during the technical interview they run. Security and IT teams supporting distributed hires move to Part III for remote-work hardening, overseas-contractor controls, and the ongoing-monitoring signals that distinguish a slow-to-adjust new hire from an active threat. Incident-response staff should jump directly to Part IV the moment a hire is suspected; its two playbooks are written to be followed during an active situation, not studied in advance. Part V is for leadership building an institutional program: training curricula, policy templates, and a checklist for a hiring runbook. Part VI holds the glossary, the red-flag summary, and the checklist for reference during a live decision.

2. Threat Context: DPRK and Similar Vectors

This chapter lays out the specific, well-documented threat that motivates the rest of the handbook: the DPRK's state-directed program of fraudulent remote IT employment, its tactics, its facilitators, and the public intelligence an organization can act on today.

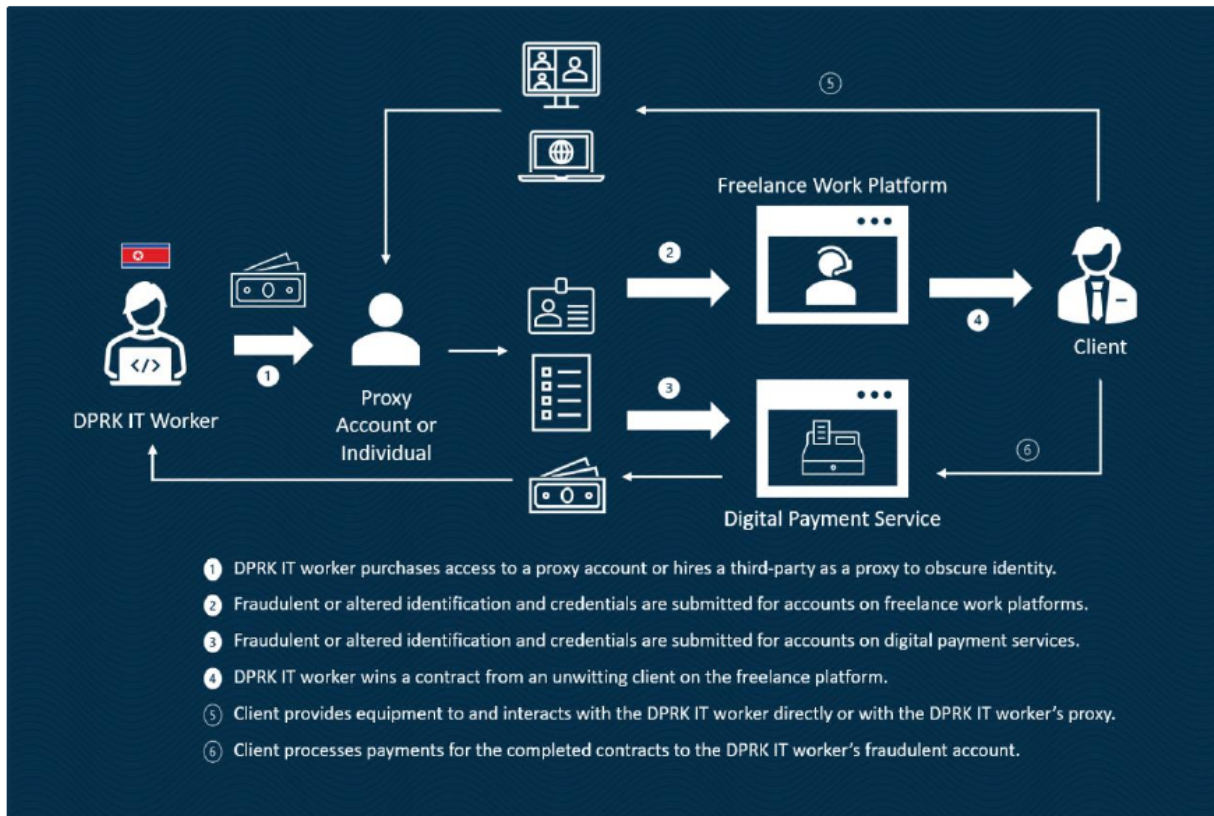


Figure. The operational chain defenders must break: proxy identity acquisition, fraudulent platform onboarding, client hiring, equipment delivery, and payment routing. It is substantially more useful for control design than a country map or agency seal because every numbered edge maps to a verification or monitoring opportunity. Source: U.S. Departments of State and Treasury and FBI, *DPRK IT Worker Advisory*, page 10, public domain (U.S. government work).

2.1 FBI/CISA/IC3 Advisories: Scope and Activities

The Federal Bureau of Investigation (FBI), the Cybersecurity and Infrastructure Security Agency (CISA), and the U.S. Department of State first published joint guidance on this threat in May 2022, warning that the DPRK dispatches thousands of skilled IT workers to China, Russia, and other locations, where they obtain freelance and full-time remote positions at companies worldwide using fabricated or stolen identities ([FBI IC3 PSA I-051622-PSA](#)). The U.S. Department of the Treasury's Office of Foreign Assets Control (OFAC) administers the sanctions program the scheme violates and maintains a standing North Korea sanctions program page that names designated front companies and facilitators as they are identified ([OFAC North Korea Sanctions Program](#)). CISA republishes and amplifies the advisory through its own alerts channel, and the FBI's Internet Crime Complaint Center (IC3) is the intake point for companies that discover after the fact that they hired into the scheme.

Independent of the government advisories, several private threat-intelligence teams track the same activity cluster under their own naming conventions, useful to know because incident reports and vendor advisories reference these names interchangeably:

Tracker	Name / cluster ID	Focus
CrowdStrike	Famous Chollima	Broad IT-worker fraud and fake-interview activity
Google Threat Intelligence Group (formerly Mandiant)	UNC5267 / "Wagemole"	Employment-fraud operations specifically
Microsoft Threat Intelligence	Jasper Sleet	LinkedIn- and Microsoft-account-based recruiting fraud
Palo Alto Networks Unit 42	CL-STA-0240 / "Contagious Interview"	Fake-recruiter malware lures against developer candidates
ESET	DeceptiveDevelopment	European-focused overlap with Contagious Interview

2.1.1 Data Extortion, Code Theft, Credential Harvesting

An IT worker who obtains a legitimate hire does not need to harvest credentials in the phishing sense; the organization issues single sign-on (SSO) access, a GitHub or GitLab seat, virtual private network (VPN) credentials, and often a deployment key as routine onboarding. The abuse happens downstream: seeding an extra Secure Shell (SSH) key into a deploy configuration, exfiltrating proprietary source before termination, or, in the crypto-specific case, inserting a logic backdoor into a contract or off-chain service the way the Munchables developer described in 1.1 reportedly did. Updated 2024 guidance from the FBI and CISA flagged a pattern beyond simple theft: workers terminated for suspected fraud or poor performance have, in a number of cases, retaliated by threatening to leak or sell the source code and internal data they still held copies of, converting a fraud case into an active extortion incident days after offboarding.

This is the scenario Part IV's response playbooks are built around: "we fired the suspicious contractor" is not the end state, it is the moment the highest-risk phase begins. An organization that has not revoked every credential, rotated every key the worker touched, and audited every commit before the termination conversation happens is exposed to exactly this follow-on extortion. Treat "credential harvesting" in this threat model as authorized access retained and abused after the trust relationship ends, not a technical compromise of a credential store, and design offboarding (Handbook 03) accordingly.

2.1.2 Revenue Generation and Sanctions Evasion

The declared purpose of the scheme, per Treasury and State Department guidance, is revenue: wages paid to a fraudulent IT worker are remitted, often after a cut taken by domestic facilitators and the DPRK's own overseas management structure, back to the regime, in violation of United Nations Security Council resolutions that cap and eventually mandated repatriation of North Korean overseas laborers (see the 1718 Sanctions Committee's consolidated resolution listing, main.un.org/securitycouncil). U.S. law treats this as a sanctions-evasion problem as much as a

fraud problem: OFAC's North Korea Sanctions Regulations make it unlawful to provide funds, goods, or services, including wages, to persons employed by or acting for the DPRK, and OFAC has designated specific front companies used to receive and launder this income.

The scale is large enough that Treasury and independent researchers describe it as a meaningful line item in DPRK state revenue, funding weapons and ballistic-missile programs alongside the regime's separate, larger cryptocurrency-theft operations. The two revenue streams share infrastructure and sometimes personnel: DPRK-linked actors were independently responsible for the roughly \$1.5 billion theft from the Bybit exchange in February 2025, attributed to the Lazarus Group and reported as the largest cryptocurrency theft on record, evidence that the same state apparatus runs the fraudulent-employment channel and the direct-theft channel in parallel. For a hiring team, a fraudulent hire is therefore not merely an internal fraud problem but a sanctions-compliance exposure; payroll, accounts payable, and vendor-onboarding teams should treat OFAC screening as part of the hiring control set, not a separate compliance silo.

2.2 Operational Tactics: AI, Deepfakes, Stolen Identities

The tradecraft behind this scheme has modernized alongside generative artificial intelligence (AI) tooling available to any operator, not only a nation-state's most resourced unit. Where earlier fraudulent applicants relied on a stolen photo and a scripted resume, current operations layer large-language-model-written application materials tailored to each posting, AI-upscaled or synthetically generated headshots, and real-time video manipulation onto a base layer that has not changed: a shared pool of stolen or purchased U.S. persons' identity documents (Social Security numbers, driver's licenses) reused across many simultaneous applications run by a small number of physical operators. CrowdStrike's threat reporting on the Famous Chollima cluster describes this shift toward AI-assisted tradecraft as a deliberate scaling strategy, letting a handful of operators sustain dozens of concurrent candidate personas across multiple companies and platforms at once ([CrowdStrike Global Threat Report](#)).

2.2.1 Fake LinkedIn Profiles and Video Interviews

LinkedIn and mainstream job boards remain the primary sourcing surface because they are where legitimate recruiters look, which is precisely why the fraud concentrates there rather than on obscure channels. A typical profile pads a plausible but unverifiable work history, uses a professionally lit photo (increasingly AI-generated rather than stolen from a real person, which defeats simple reverse-image search), and applies to dozens of open roles across multiple companies in parallel, often with response times and English fluency that read as slightly too fast and too polished for a genuine individual juggling that volume alone. Microsoft's threat-intelligence team, tracking this cluster as Jasper Sleet, reported disabling more than 3,000 known Microsoft consumer accounts (Outlook.com, Hotmail, and related services) tied to the operation, giving a sense of the scale a single platform observes ([Microsoft Threat Intelligence, "Jasper Sleet: North Korean remote IT workers' evolving tactics to infiltrate organizations"](#)).

The video interview is the stage most likely to leak a tell, because it is the hardest step to fully script. Investigators and hiring managers have documented interviews where the candidate's spoken answers lag noticeably behind the question, consistent with a remote handler typing responses that the on-camera "candidate" reads off-screen, or where the candidate's stated location, accent, and background do not cohere with the biography on their resume. None of these signals is individually conclusive; a nervous, non-native-English-speaking candidate in a legitimate interview can present some of the same surface behavior, which is why Section 2.4 treats them as a checklist to escalate, not a checklist to reject on sight.

2.2.2 Face-Swapping and Reused Contact Details

Real-time face-swapping software, the same class of generative adversarial network (GAN) tooling behind consumer deepfake apps, has been documented running as a virtual camera source during video interviews, letting an operator present a synthetic face over their own on a live call rather than relying on a pre-recorded loop. Public guidance on synthetic media describes the visual tells: artifacts around the hairline and jaw, unnatural blinking, and most distinctively, visible glitching when the presented face is partially occluded, for instance when a hand passes in front of it, because the swap model has to track and re-render the face boundary in real time. KnowBe4, a security-awareness training vendor, published a detailed account after it inadvertently hired a fraudulent worker in 2024: the individual's application photo had been AI-enhanced against a stolen identity, and the hire attempted to load information-stealing malware onto the company laptop within minutes of receiving it, caught by the company's own endpoint detection and reported publicly as a case study ([KnowBe4 blog](#)).

A second, more mundane tell scales better for defenders than deepfake detection: contact-detail reuse. Because a small number of operators run many personas, the same voice-over-IP (VOIP) phone number, email-naming pattern, or even bank routing and account number recurs across applications submitted under different names to the same or different companies. Cross-referencing applicant contact metadata against a shared blocklist, ideally pooled across companies through the information-sharing channels described in Section 2.6, catches this reuse even when the video and resume for each individual persona are convincing on their own.

2.3 U.S.-Based Facilitators (Witting and Unwitting)

The scheme depends on a domestic proxy to make an overseas worker's traffic, timezone, and device look American, and U.S. Department of Justice (DOJ) prosecutions have made the mechanics of that proxy role public. The reference case is Christina Chapman, an Arizona woman who ran what investigators called a "laptop farm": company-issued laptops, more than a hundred at the height of the operation, physically located in her home and running remote-access software that let overseas DPRK-linked workers log in and appear to work from a U.S. IP address during U.S. business hours. DOJ's case described the scheme as helping place workers at more than 300 U.S. companies and generating several million dollars in fraudulently obtained wages; Chapman

pleaded guilty in early 2025 to conspiracy to commit wire fraud, aggravated identity theft, and money laundering, and was sentenced to a multi-year federal prison term later that year ([Department of Justice press releases](#)). Investigators recovered dozens of stolen U.S. identities at her residence along with keyboard-video-mouse (KVM) switches, hardware that captures a laptop's video output and injects keyboard and mouse input over the network, letting a remote operator control the machine as if seated in front of it.

Chapman's role illustrates the witting facilitator: a paid, knowing participant. A second pattern documented in related DOJ cases, including prosecutions of facilitators elsewhere in the country and a Ukraine-based national who ran a platform connecting workers to U.S. staffing gigs, is the unwitting facilitator: someone recruited through what looks like an ordinary remote job (often "package inspection" or "laptop reshipping"), who never learns their home has become a node in a fraud scheme until federal agents arrive.

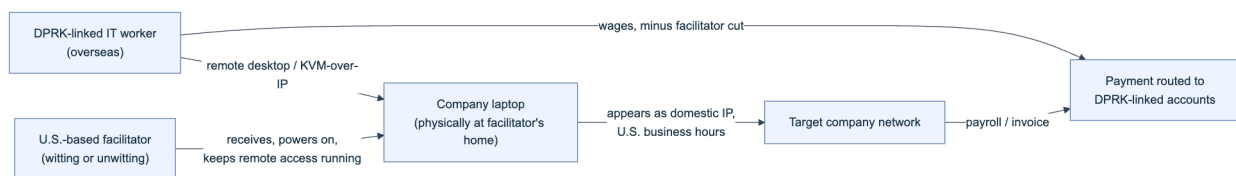


Figure 1. The laptop-farm proxy model. The facilitator's only technical contribution is often powering on hardware and keeping remote-access software running; the DPRK-linked worker does the actual work remotely, and the wage flows back out through the same relationship.

2.4 Recruitment Red Flags (ASIS and Law Enforcement Guidance)

No single indicator proves fraud, and treating any one signal as disqualifying invites both false positives against legitimate remote and immigrant candidates and false negatives against an operator who has learned to avoid the obvious tells. ASIS International, the professional association for security-management practitioners, recommends the same layered-indicator approach used elsewhere in personnel security: no single red flag triggers action, but a cluster of several from independent categories (identity, behavior, payment, technical) warrants escalation to a documented review rather than a quiet rejection or a quiet hire.

Category	Indicator	Why it matters
Identity	Notarized ID or reference documents do not match the person on video calls	Suggests a borrowed or purchased identity
Behavior	Persistent camera-off requests, or camera on with visible artifacts around the face against the background	Consistent with deepfake or hidden-handler setups
Behavior	Answers to unscripted follow-up questions lag or are inconsistent with earlier written responses	Consistent with a remote party feeding answers

Category	Indicator	Why it matters
Payment	Direct-deposit account holder name differs from the candidate's name	Classic facilitator or money-mule pattern
Payment	Repeated, urgent requests to change banking details after hire	Facilitator account cycling or law-enforcement pressure
Logistics	Insistence on shipping company equipment to an address other than the stated home address	Laptop-farm delivery pattern
Technical	Git commit timestamps or VPN login times cluster around a non-U.S. working day despite a claimed U.S. location	Timezone mismatch between claimed and actual location
Technical	Portfolio, resume, or reference contact details overlap with a previously rejected or flagged candidate	Shared identity kit reused across personas

2.5 Techniques, Tactics, and Procedures (TTPs)

Mapping this scheme against a structured framework, rather than a loose list of anecdotes, helps a security team brief it consistently and update it as tactics shift. **MITRE ATT&CK** (Adversarial Tactics, Techniques, and Common Knowledge), the widely adopted knowledge base of adversary behavior, offers the general reconnaissance-through-impact structure this handbook borrows loosely for the hiring context: reconnaissance is scanning job boards, resource development is assembling the stolen-identity kit and AI tooling, initial access is the hire itself, and collection and exfiltration are the code theft and extortion covered in 2.1.1. For threats specific to digital-asset organizations, MITRE's Center for Threat-Informed Defense maintains **AADAPT** (Adversarial Actions in Digital Asset Payment Technologies), an ATT&CK-style framework purpose-built for cryptocurrency threats, useful when the fraudulent hire's objective is a treasury multisig rather than generic corporate data. Neither framework yet carries a dedicated technique ID for fraudulent-employment initial access, itself a gap worth flagging: this vector currently lives between HR fraud and cyber threat intelligence, owned fully by neither discipline.

2.5.1 How Threat Actors Find Roles; Am I Interviewing One? Did I Hire One?

Operators find roles the same way any high-volume job seeker does, by monitoring the same postings recruiters see: company career pages, LinkedIn, Indeed, and, for contractor roles specifically, the freelance marketplaces (Upwork, Fiverr, Toptal) where identity verification is often lighter than a formal applicant-tracking workflow. Remote-only postings, postings that explicitly welcome international asynchronous work, and postings for roles with direct code, key, or treasury access are disproportionately targeted, because they promise both easy entry and high-value access in one listing.

Two practical questions recur for a hiring team, and they need different answers. “Am I interviewing one?” is answered in the moment, using the Section 2.4 indicator table against the live interaction: does the identity documentation match the video, does the conversation hold up under an unscripted follow-up, do the payment and logistics details cohere. “Did I hire one?” is answered retrospectively, using signals only visible after weeks of employment: commit and login timestamps against claimed timezone, whether the employee’s device telemetry is consistent with a single physical machine versus KVM-mediated remote control, and whether payment or banking-detail-change requests match the pattern in the red-flag table. Both questions route to the same decision point once escalated, which the diagram below frames as a single funnel.

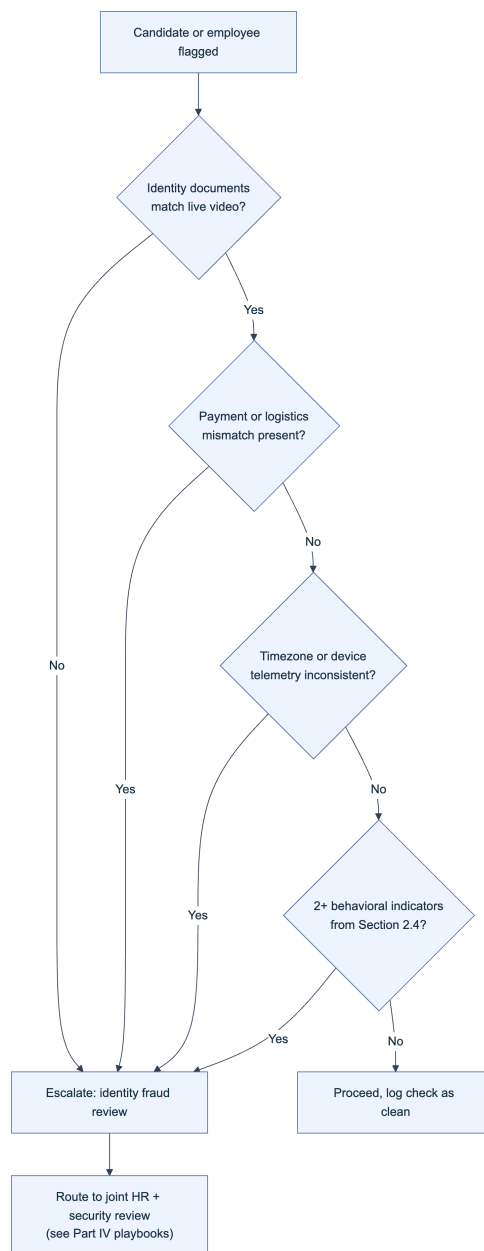


Figure 2. A single escalation funnel usable both pre-hire (interview stage) and post-hire (employment monitoring). Any branch reaching “yes” routes to the same joint HR-security review, not an immediate rejection or termination.

2.6 Use of Public Advisories and Intelligence

Treat the advisories in Section 2.1 as a living feed, not a one-time read. The FBI's IC3 and CISA both push updates as tactics shift, and OFAC periodically adds newly identified front companies and facilitators to its sanctions list, changes that matter directly to vendor onboarding: a subcontracted dev shop that shares an address, bank account, or beneficial owner with a designated entity is itself a sanctions exposure, not merely a fraud risk. Subscribe to IC3 and CISA alert feeds, and check counterparties, including individual contractors billing through personal LLCs, against the OFAC Specially Designated Nationals list before onboarding and on a recurring cadence afterward, since designations happen after a relationship often already exists.

The private trackers named in Section 2.1 (CrowdStrike, Google Threat Intelligence Group, Microsoft, Unit 42, ESET) publish updates faster than government advisories can be revised, and following even one closely gives earlier warning of tactic shifts, such as the move toward AI-assisted deepfake interviews in Section 2.2. Blockchain-analytics firms (Chainalysis, TRM Labs, Elliptic) separately publish DPRK-linked wallet-clustering research that a finance or security team can screen outbound vendor and payroll addresses against as a final check. Finally, participate in information sharing where it exists: an Information Sharing and Analysis Center (ISAC) relevant to your sector, or an informal peer network of Web3 security teams, is how a blocked phone number, email pattern, or bank account discovered by one company becomes a preemptive block at the next.

Key controls for Part 1

- Treat every hire, including contractors sourced through freelance marketplaces, as a control decision with the same blast radius as a smart contract change; scope access accordingly before granting it.
- Screen candidates and vendors against the layered red-flag table (2.4), escalating on clusters of indicators from independent categories, not single signals.
- Screen vendors, subcontractors, and individual contractor entities against the OFAC Specially Designated Nationals list on a recurring cadence, not only at initial onboarding.
- Subscribe to FBI/IC3 and CISA advisory feeds and at least one private threat-intelligence tracker (Section 2.1) so tactic shifts, such as AI-assisted deepfake interviewing, reach your hiring team before they reach your postings.
- Build the pre-hire (“am I interviewing one?”) and post-hire (“did I hire one?”) checks into a single escalation path that routes to joint HR-security review, per Figure 2, rather than leaving either question to an individual hiring manager’s judgment.

Part II: Hiring Security

Hiring is the first control point in the insider threat lifecycle, and for Web3 and crypto-adjacent employers it is also the point most heavily targeted by state-directed fraud. This part covers the mechanics of building a hiring pipeline that resists impersonation: where you post roles and how you vet the channel, how you run interviews so identity and skill are both verified rather than assumed, how you select and bind vendors who supply contractors on your behalf, and what background checks can and cannot lawfully establish before an offer goes out. The controls here are the ones that would have stopped, or did stop, the fraud patterns documented in Part 1.

3. Job Posting and Sourcing

Where a role is advertised determines who applies to it, and the Democratic People's Republic of Korea (DPRK) IT worker apparatus has learned exactly which channels convert fastest into fraudulent placements. This chapter treats sourcing as the first filter, not an afterthought to interviewing.

3.1 Controlled Distribution and Verification of Channels

Post roles only through channels you control end to end: your own careers page, your applicant tracking system (ATS), and a small, named set of recruiting partners you have vetted. Every other channel, including general job boards, LinkedIn outreach from unverified recruiters, and crypto-specific Discord or Telegram job channels, is a channel an operator can scrape, clone, or use to route a stolen-identity application directly into your funnel. The [May 2022 US Treasury, State Department, and FBI advisory](#) already flagged freelance and staffing platforms as a primary entry point for DPRK IT workers using stolen or fabricated identities, and later reporting from [Google Cloud's Mandiant](#) confirms operators actively monitor these boards for roles that combine remote-only terms with weak identity requirements. Verification of a channel means confirming the recruiter or platform account is who it claims to be (call the firm's main line, not the number in the outreach message), that job posts are not being mirrored or cloned on secondary boards under your company name, and that applications are captured in a single system of record rather than scattered across email inboxes where duplicate identities are hard to spot.

Channel	Control level	Recommended posture
Company careers page + ATS	Full control	Primary channel; all applications route here
Named recruiting partners (vetted, contracted)	High control	Permitted, with a signed vendor agreement (Section 5)
LinkedIn direct outreach (unsolicited recruiters)	Low control	Verify recruiter identity before any exchange of documents
General freelance/gig marketplaces	Very low control	Route through Section 3.2 risk review before use
Crypto-specific Discord/Telegram job channels	Very low control	Treat as high-risk sourcing (Section 3.2)

3.2 Avoiding High-Risk Sourcing Where Appropriate

Some sourcing channels carry a documented, elevated concentration of fraudulent applicants and should be avoided outright for sensitive roles, or used only with compensating controls layered on top. The 2022 advisory and the October 2023 [FBI/IC3 follow-up guidance](#) both single out general freelance and remote-work marketplaces and cryptocurrency payment platforms as venues DPRK operators exploit because identity requirements are thin and payment can be routed to accounts that are not tied to a verified individual. This does not mean freelance platforms are off limits for every engagement, remote-first hiring is a legitimate and often necessary model, but it does mean the decision to source through one should be a documented risk decision, not a default. Weigh the sensitivity of the role (does it touch production systems, treasury operations, or private keys) against the platform's identity assurance, and where the marketplace is used anyway, require its own verified-identity tier, insist on real-time video before any offer, and never accept payment routing changes requested after the engagement starts, a pattern the advisory calls out explicitly as a fraud indicator. For roles above a defined sensitivity threshold (Section 6.3), high-risk sourcing should be excluded from the vendor pool entirely rather than compensated for.

4. Interview and Assessment

The interview is the last point before an offer where a human evaluator can catch what automated screening misses. DPRK operators have adapted specifically to defeat weak interview processes, so the process itself needs to assume an adversarial candidate exists in every pool.

4.1 Technical and Identity Verification

Treat technical competence and identity as two separate claims that both need independent proof, because a skilled engineer and a stolen identity are not mutually exclusive; DPRK operators are frequently competent developers operating under someone else's name. Technical verification

should include a live, proctored coding or systems exercise, not only an asynchronous take-home that can be completed by a different person entirely. Identity verification should follow the current **NIST Special Publication 800-63A Revision 4** outcomes. Revision 4 no longer treats IAL1 as self-asserted: IAL1 requires acceptable identity evidence, validation of core attributes and a government identifier against authoritative or credible sources, and verification that the applicant owns the evidence. IAL2 requires stronger or multiple evidence and supports non-biometric, biometric, and digital-evidence pathways; biometrics are not universally mandatory. IAL3 requires on-site attended proofing, although the proofing agent may participate remotely through a CSP-controlled kiosk, and retains a biometric sample. For a remote hire with production or customer-data access, use a conformant IAL2-capable service as the practical floor and document the evidence class, validation source, verification pathway, proofing type, exception handling, privacy impact, and result. A liveness-checked selfie matched to one ID is one possible biometric pathway, not by itself proof that the entire IAL2 outcome has been met. Screen names and entities against applicable sanctions lists, including the Treasury Office of Foreign Assets Control (OFAC) Specially Designated Nationals (SDN) list, under legal and privacy review.

Verification layer	Method	Minimum assurance target
Identity proofing	Conformant service; sufficient evidence, authoritative/credible-source validation, and recorded non-biometric, biometric, or digital-evidence verification pathway	Documented NIST IAL2 outcome
Sanctions screening	Name/entity match against OFAC SDN list	Pass, documented
Technical skill	Live, proctored assessment	Panel-reviewed, scored
Contact artifact reuse	Phone/email cross-check against prior applicants	Zero unresolved matches

4.2 In-Person or Unobscured Video; Direct Verification with Institutions



Figure. Example output from a generative adversarial network: neither face belongs to a real person, illustrating the AI-generated headshots and synthetic overlays that a camera-on interview policy is designed to expose. Source: [Wikimedia Commons](#), public domain.

Require live, unobscured video for every interview round, camera fully on, no virtual backgrounds that could mask a green-screen deepfake rig, and reserve at least one round for spontaneous, unscripted questions the candidate cannot have rehearsed with a script feeding a synthetic overlay. The July 2025 [FBI/IC3 advisory](#) recommends specific live checks that are cheap to run and hard for a real-time deepfake pipeline to pass cleanly: ask the candidate to turn their head in profile, wave a hand in front of their face, or briefly point the camera out a window to confirm a claimed location and time of day. KnowBe4’s own hiring pipeline conducted [four separate video interviews](#) with a candidate later confirmed to be a DPRK operative using a stolen identity and an AI-enhanced stock photo, and the interviews alone did not catch it; the company’s post-mortem is a useful case study in why video presence must be paired with independent verification, not treated as sufficient on its own. For sensitive roles, require an in-person meeting where feasible, even a single onboarding-day visit to a regional office. For prior employment and education, call the institution’s published main switchboard number, never the number supplied on the resume or by a “reference” who answers suspiciously fast, and confirm dates and title directly with HR or registrar staff.

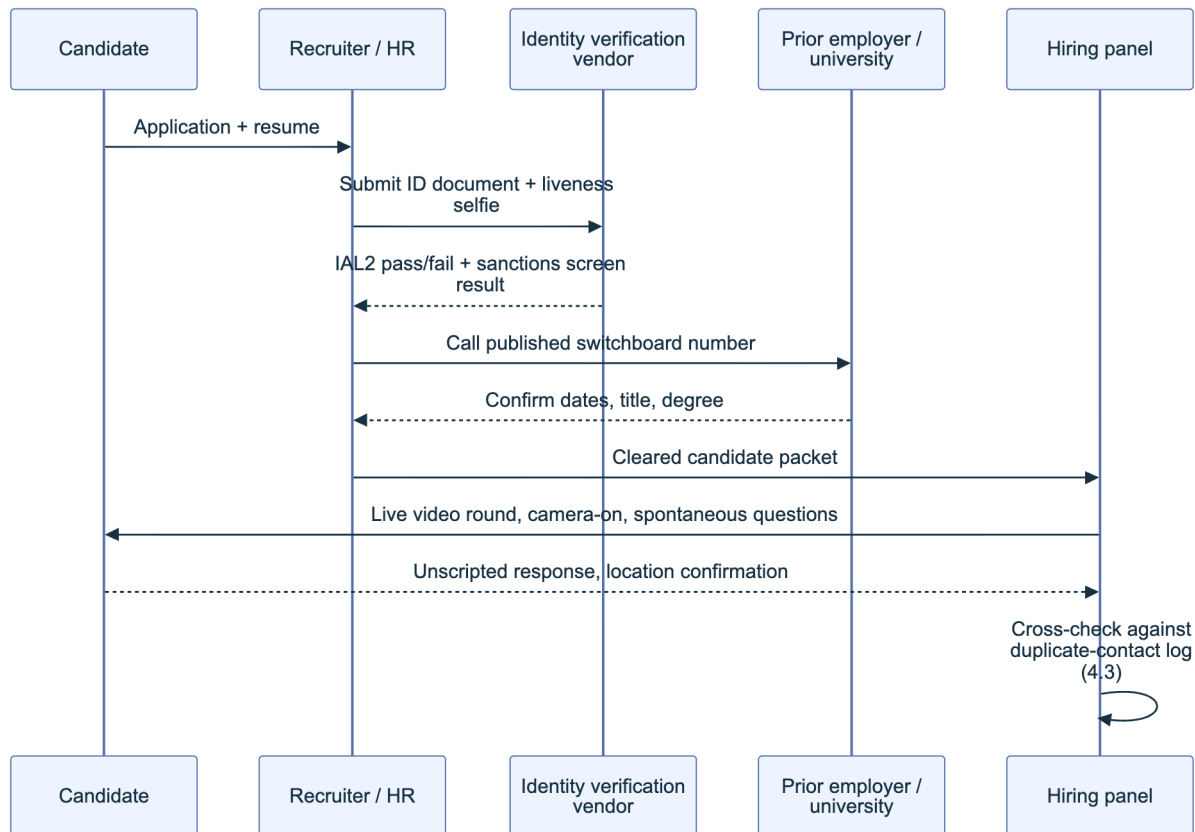


Figure 1. The interview verification chain. Each stage produces independent evidence; no single stage is treated as sufficient on its own.

4.3 Consistent Process and Documentation

Run every candidate through the same sequence of steps, the same question set per round, and the same documentation requirement, because inconsistency is what lets a fraudulent application slip through a gap another candidate would have been forced through. A standardized process also creates the dataset needed to catch the specific fraud pattern both the 2022 advisory and Mandiant’s UNC5267 reporting describe: the same phone number, email address, or bank routing detail reused across resumes that claim to be different people. Maintain a central applicant intake log and run a duplicate-detection pass before any interview is scheduled.

```

-- Illustrative: flag contact-artifact reuse across distinct applicant records
SELECT phone_number, COUNT(DISTINCT applicant_id) AS applicant_count
FROM applicant_intake
GROUP BY phone_number
HAVING COUNT(DISTINCT applicant_id) > 1
UNION ALL
SELECT email_address, COUNT(DISTINCT applicant_id)
FROM applicant_intake
GROUP BY email_address
HAVING COUNT(DISTINCT applicant_id) > 1;

```


Document every interviewer's notes in the ATS rather than in personal messages or memory, log which verification steps were completed and by whom, and require panel sign-off before an offer. A documented process also produces the audit trail that matters if a hire is later found to be fraudulent: it is the record that shows what was checked, when, and by whom, which is what regulators and law enforcement will ask for first.

4.4 Red Flags During Interview (Technical, Behavioral, Inconsistencies)

No single red flag is proof of fraud, and treating any one indicator as disqualifying invites false accusations against legitimate candidates, particularly those in different time zones or with limited video bandwidth. Weighted together, a cluster of these indicators from the FBI advisory series, Mandiant's UNC5267 reporting, and CrowdStrike's tracking of the actor it calls FAMOUS CHOLLIMA (documented across **304 incidents in 2024**, a share involving insider access) should trigger a hold on the hiring decision pending further verification.

RED FLAG INDICATORS

Freelance work and payment platform companies should be aware of the following activity that may be indications or behaviors of DPRK IT workers who may be using their platforms.

- Multiple logins into one account from various IP addresses in a relatively short period of time, especially if the IP addresses are associated with different countries;
- Developers are logging into multiple accounts on the same platform from one IP address;
- Developers are logged into their accounts continuously for one or more days at a time;
- Router port or other technical configurations associated with use of remote desktop sharing software, such as port 3389 in the router used to access the account, particularly if usage of remote desktop sharing software is not standard company practice;
- Developer accounts use a fraudulent client account to increase developer account ratings, but both the client and developer accounts use the same PayPal account to transfer/withdraw money (paying themselves with their own money);
- Frequent use of document templates for things such as bidding documents and project communication methods, especially the same templates being used across different developer accounts;
- Multiple developer accounts receiving high ratings from one client account in a short period, with similar or identical documentation used to establish the developer accounts and/or the client account;
- Extensive bidding on projects, and a low number of accepted project bids compared to the number of projects bids on by a developer; and
- Frequent transfers of money through payment platforms, especially to PRC-based bank accounts, and sometimes routed through one or more companies to disguise the ultimate destination of the funds.

Companies employing freelance developers should be aware of the following activity that may be indications or behaviors of DPRK IT workers.

- If a freelance software development website or payment platform account has been shut down or the worker contacts the employer requesting use of a different account, especially if registered to a different name;
- Use of digital payment services, especially PRC-linked services;

Figure. Platform and payment indicators from the original joint advisory. These are observable control inputs—multi-country logins, shared IPs, long-running sessions, remote-desktop configuration, linked payment accounts—not demographic proxies. Feed them into case correlation, never use one row as an automatic hiring verdict. Source: *U.S. Departments of State and Treasury and FBI, DPRK IT Worker Advisory*, page 8, public domain (U.S. government work).

- Inconsistencies in name spelling, nationality, claimed work location, contact information, educational history, work history, and other details across a developer's freelance platform profiles, social media profiles, external portfolio websites, payment platform profiles, and assessed location and hours;
- Surprisingly simple portfolio websites, social media profiles, or developer profiles;
- Direct messaging or cold-calls from individuals purporting to be C-suite level executives of software development companies to solicit services or advertise proficiencies;
- Requests to communicate with clients and potential clients on a separate platform than the original freelance platform website where the client found the IT worker;
- An employer proposes to send documents or work-related equipment such as a laptop to a developer, and the developer requests that items be sent to an address not listed on the developer's identification documentation. Be particularly suspicious if a developer claims they cannot receive items at the address on their identification documentation;
- Seeking payment in virtual currency in an effort to evade KYC/AML measures and use of the formal financial system;
- Requesting payment for contracts without meeting production benchmarks or check-in meetings;
- Inability to conduct business during required business hours;
- Incorrect or changing contact information, specifically phone numbers and emails;
- Biographical information which does not appear to match the applicant;
- Failure to complete tasks in a timely manner or to respond to tasks;
- Inability to reach them in a timely manner, especially through "instant" communication methods; and
- Asking co-workers to borrow some of their personal information to obtain other contracts.

Figure. Employer-facing indicators from the same advisory, completing the official list with cross-profile identity inconsistencies, mismatched equipment destinations, virtual-currency payment requests, unreachable working hours, changing contact details, and requests to reuse another person's identity. Corroborate across categories before escalation. Source: *U.S. Departments of State and Treasury and FBI, DPRK IT Worker Advisory, page 9, public domain (U.S. government work).*

Category	Indicator
Technical	Below-average code quality or unfamiliarity with claimed seniority-level concepts during live assessment
Technical	Reliance on AI coding tools to answer basic questions about their own submitted work
Behavioral	Reluctance or refusal to enable camera, or camera enabled only briefly
Behavioral	Refuses a second, spontaneous video call after passing a scripted first round
Behavioral	Unnatural lip-sync, lighting seams, or blinking irregularities suggesting a real-time deepfake overlay
Behavioral	Generic, evasive, or rehearsed-sounding answers to personal or local-context questions
Inconsistency	Interview availability clusters at hours implausible for the claimed time zone
Inconsistency	Requests to ship a company laptop to an address that does not match the identification document

Category	Indicator
Inconsistency	Payment or banking details that partially match another applicant's record
Inconsistency	Resume content, project history, or writing style duplicated near-verbatim from another applicant
Inconsistency	Background, accent, or claimed location inconsistent with the video feed's visible details

4.5 Monitoring: Multi-Country Logins and Unusual Network Traffic

Verification does not end at the offer letter; the strongest signals often surface only after the laptop ships. Mandiant's UNC5267 tracking found that DPRK IT workers frequently connect corporate laptops through **IP-based Keyboard-Video-Mouse (KVM) devices**, hardware that lets a facilitator physically hold the shipped laptop in a "laptop farm" while the actual worker operates it remotely from overseas, commonly over Astrill VPN egress traced to China or North Korea (Google Cloud, 2024). The same reporting documents use of "Caffeine" mouse-jiggling software to keep multiple job laptops appearing active simultaneously, since many operators hold several jobs at once. Detect these patterns with conditional access policies that alert on geolocation mismatch between the shipping address and login IP, on VPN egress from flagged ranges, on multiple concurrent sessions from geographically implausible locations, and on the appearance of unauthorized remote-administration software (AnyDesk, TeamViewer, Chrome Remote Desktop, RustDesk) on a corporate device shortly after provisioning.

```
# Illustrative SIEM alert logic, not a product-specific syntax
alert: dprk-multi-country-login
conditions:
  - login_ip_country != shipping_address_country
  - AND concurrent_sessions > 1 for single_user_account
  - OR vpn_egress_range IN [flagged_astrill_ranges]
  - OR new_process_name IN [anydesk.exe, teamviewer.exe, rustdesk.exe, chromere-
    motedesktop.exe]
    AND days_since_provisioning < 7
action: suspend_access, notify_security_and_hr, do_not_notify_manager_alone
```

Require hardware-bound multi-factor authentication tied to the shipped device, request laptop serial number confirmation at first login, and schedule periodic, unannounced video spot checks for fully remote staff. Part 4 of this handbook (Detection and Response) extends this monitoring into full insider-threat telemetry once an employee is past onboarding.

5. Vendor and Contractor Selection

Direct hires are only half the exposure. Staffing agencies, development shops, and individual contractors introduce a second identity-verification chain that your own controls do not automatically reach unless the contract requires it.

5.1 Due Diligence on Offshore and Remote Vendors

Vet a staffing vendor with the same rigor as a direct hire, because the vendor's own hiring practices become your exposure the moment a contractor gets network access. The June 2025 **Department of Justice coordinated action** against DPRK IT worker networks illustrates the mechanism directly: US-based facilitators, in that case charged alongside Chinese and Taiwanese co-conspirators, ran laptop farms and financial pass-through accounts on behalf of overseas operators, letting the workers present as US-based contractors to more than 100 companies. Before engaging any staffing agency or offshore development vendor, require them to disclose their own identity-verification workflow for every named individual they will place on your account, reserve the right to audit that workflow, and require named-individual attestations rather than accepting a vendor's blanket assurance that "our people are vetted." Cross-reference the vendor's own corporate registration and beneficial ownership where the engagement is significant, since shell staffing entities are a documented facilitation pattern in these schemes.

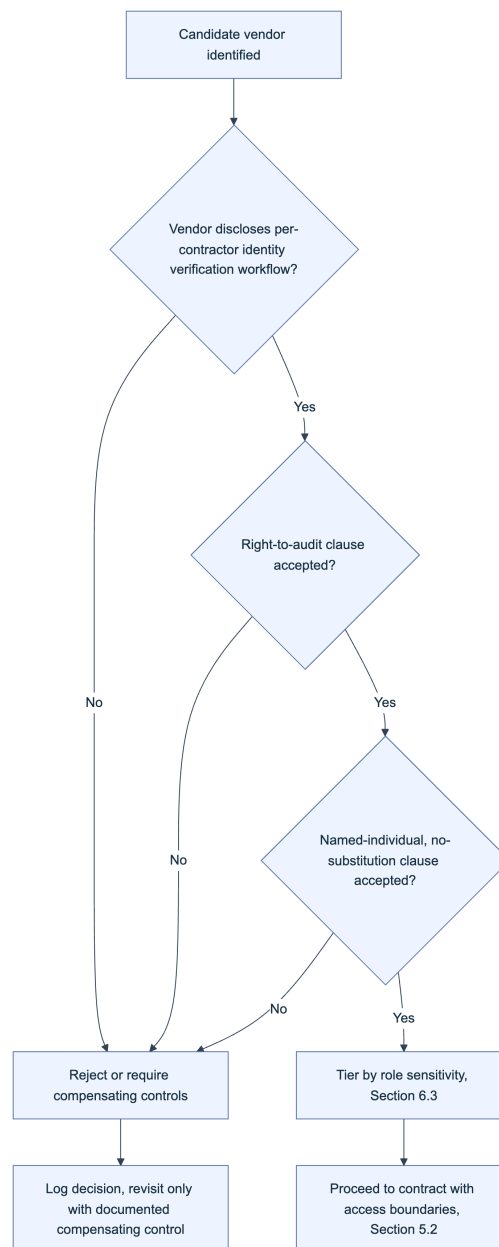


Figure 2. Vendor due diligence gate. A vendor that cannot or will not produce individual-level verification evidence should not receive access-bearing placements.

5.2 Contract and Access Boundaries

Write the contract to close the exact gap the laptop-farm pattern exploits: undisclosed substitution of who is actually doing the work. Every vendor agreement supplying remote personnel should include a named-individual clause naming the specific person authorized to perform the work, a no-subcontracting and no-substitution clause requiring written approval and re-verification before any personnel change, a prohibition on connecting company-issued or company-accessed equipment through third-party KVM or remote-administration hardware, and a right to conduct unannounced video verification calls with the named individual at any time during the engagement. Bind shipping addresses for any provided equipment to the identity-verified address on file and require immediate notice of any change.

CONTRACT CLAUSE (illustrative)

5.4 Named Individual; No Substitution. Vendor shall perform the Services solely through the individual(s) identified in Exhibit C, each of whom has completed the identity verification set out in Exhibit D. Vendor shall not substitute, subcontract, or permit any other individual to perform the Services without Client's prior written consent and completion of equivalent verification for the substitute individual. Vendor shall not connect Client-provided equipment, or equipment used to access Client systems, through any third-party KVM, remote-hands, or remote-administration hardware or software not expressly approved by Client. Breach of this Section is grounds for immediate termination for cause and forfeiture of unpaid fees.

5.3 Ongoing Monitoring and Review

Treat vendor-supplied access as a standing risk to review on a schedule, not a one-time gate cleared at contract signing. Require periodic, unannounced video check-ins with named individuals at an interval proportional to access sensitivity, monthly for privileged roles, quarterly otherwise, and compare the person on camera against the identity-verification record each time. Monitor invoicing and payment patterns for the anomalies the advisories flag repeatedly: requests to split payment across multiple accounts, requests to route payment through a different name than the named individual, and any request for cryptocurrency payment in place of the contracted payment method, which the [July 2025 FBI/IC3 advisory](#) specifically recommends against accepting. Review work-product quality trends over time; a documented drop in output quality or a sudden change in coding style and commit patterns for a long-tenured contractor is consistent with the DPRK IT worker practice of one operator holding, or later taking over, several concurrent job identities.

6. Background and Verification (Legal and Practical)

Background checks are the most legally constrained control in this handbook, because what you are permitted to ask, collect, and retain about a candidate varies sharply by jurisdiction. This chapter separates what the law allows from what is practically achievable, since the two are not the same everywhere.

6.1 Legal Constraints by Jurisdiction

A background check process built around a single jurisdiction's rules will either under-verify candidates elsewhere or violate local law. In the United States, the Fair Credit Reporting Act (FCRA) governs checks run through third-party consumer reporting agencies: it requires clear written disclosure, candidate authorization, and a defined adverse-action process (pre-adverse-action notice, a chance to dispute, then final notice) before declining a candidate based on report contents, and many states layer additional restrictions such as "ban the box" limits on when criminal history can be requested. In the European Economic Area, the General Data Protection

Regulation (GDPR) treats criminal-record data as a special category with narrow lawful bases for processing, requires a documented legal basis and proportionality assessment before running any check, and gives candidates rights to access and erasure that constrain how long check results can be retained. Consult local employment and privacy counsel before deploying a uniform global background-check template.

Jurisdiction	Governing framework	Key constraint
United States	FCRA + state law	Disclosure, authorization, adverse-action process; state-level criminal-history timing limits
European Economic Area	GDPR + national labor law	Criminal record is special-category data; narrow lawful basis, proportionality, retention limits
United Kingdom	UK GDPR + DBS regime	Disclosure and Barring Service checks tiered by role; strict standard/enhanced eligibility
Other jurisdictions	Varies (data protection + labor law)	Assess per engagement; do not assume US or EU rules transfer

Because criminal-history checks are unevenly available across jurisdictions, identity verification (Section 4.1) becomes the control that travels globally: confirming a candidate is who they claim to be is lawful nearly everywhere, while confirming what they may have done is not.

6.2 Reference and Credential Verification

Verify credentials at the source, not through the candidate’s supplied contact path. For education, use an institutional verification service such as the [National Student Clearinghouse’s DegreeVerify](#), which confirms degree and attendance records directly against data submitted by the institution itself, closing the diploma-mill and fabricated-transcript gap that a candidate-supplied PDF cannot. For employment references, call the company’s published main number and ask to be routed to HR or the stated manager, rather than dialing a number the candidate or a “reference” provided, since DPRK operator networks have used facilitators to pose as references reachable at numbers under their own control. Treat a reference who answers unusually quickly, gives suspiciously polished answers, or cannot describe specific day-to-day work with the candidate as a signal to escalate, not close. Where the role warrants it, corroborate through a second, independent channel, a public professional profile with consistent tenure dates and endorsements from names you can separately verify, rather than a single reference call.

6.3 Handling of Sensitive Roles

Not every role carries the same downstream risk, and verification effort should scale with what the role can reach. Define sensitivity tiers before hiring begins and apply them consistently across direct hires and vendor placements alike, since the access, not the employment type, is what creates risk.

Sensitivity tier	Example roles	Verification floor	Access staging
Tier 1 (low)	Non-technical, no system access	Documented IAL1 outcome under SP 800-63A Rev. 4, standard reference check	Standard onboarding
Tier 2 (elevated)	Engineers with production or customer-data access	IAL2, institutional credential check, live technical assessment	Least-privilege grant, review at 30/60/90 days
Tier 3 (sensitive)	Private-key custody, treasury operations, smart-contract deploy authority, code merge to production	IAL2 plus notarized identity proof, in-person meeting where feasible, sanctions screening	Staged access behind a probation period; hardware-bound MFA; no unsupervised key custody until tier review complete

For Tier 3 roles, favor in-person onboarding meetings even for otherwise fully remote teams, and hold sensitive-scope access (deployment keys, treasury signing authority, production database credentials) behind a deliberate staging period rather than granting it on day one. The Employee Lifecycle Security Handbook (03) covers the offboarding half of this same access-staging discipline, and Part 4 of this handbook extends sensitive-role monitoring into ongoing insider-threat detection once the person is past their probation window.

Key controls for Part 2

- Route all hiring through owned, controlled channels; treat general freelance marketplaces and unsolicited outreach as high-risk sourcing requiring documented compensating controls.
- Separate identity verification (documented IAL2 evidence, validation, and verification outcome for elevated roles) from technical verification (live, proctored assessment) and require both; treat selfie/liveness as one possible pathway, not a complete IAL2 definition.
- Run every candidate through the same documented process, and screen intake data for reused phone numbers, emails, or payment details across “different” applicants.
- Require live, unobscured video with spontaneous verification prompts across multiple rounds, and verify employment and education directly with the issuing institution.
- Monitor post-hire for geolocation mismatch, KVM and remote-administration tooling, and mouse-jiggler activity on shipped equipment.
- Hold vendors and staffing agencies to named-individual, no-substitution, right-to-audit contract terms, and re-verify on a recurring schedule.
- Scale background-check rigor to local law, and scale verification depth and access staging to role sensitivity rather than employment type.

Part III: Remote Work and Overseas Consultation

A verified hire is not a closed case: the same operators who pass an interview must still be managed as remote or overseas workers with real system access. This part covers the controls that apply after an offer letter is signed, from device and network requirements through least-privilege access design, the specific compartmentalization needs of offshore consultants and distributed teams, the behavioral indicators that surface once a threat actor is on payroll, and the offboarding and organizational hardening that close the loop. The guidance assumes the reader has already absorbed the DPRK threat model in Part I and the pre-hire screening controls in Part II; this part is where those controls meet the daily reality of a remote workforce.

7. Remote Work Security

Remote work security here means the technical baseline every distributed hire, employee or contractor, must meet before touching production systems, plus the access design and communication discipline that limits what a single compromised or malicious account can do.

7.1 Device and Network Expectations

The device a remote worker uses is the first control point, and it is also the point the [Christina Chapman “laptop farm” case](#) showed is routinely subverted. Chapman ran a residence in Arizona that received company-issued laptops on behalf of overseas IT workers, plugged them into KVM (keyboard-video-mouse) devices, and ran remote access software so DPRK operatives thousands of miles away could operate them, letting all 300-plus victim companies believe their new hire’s laptop was sitting in a U.S. home ([DOJ press release](#); [BleepingComputer](#)). A shipped laptop, on its own, proves nothing about who is typing on it.

Set concrete, enforceable device and network expectations rather than trusting shipping addresses:

- **Company-managed hardware only.** Issue enrolled, MDM (mobile device management)-managed laptops for any role touching source code, customer data, or funds; refuse personal-device requests for these roles. [NIST SP 800-46 Rev. 2](#) treats organization-issued devices as the baseline case and BYOD (bring your own device) as the higher-risk exception requiring compensating controls.
- **Bind identity to hardware.** Require hardware-backed multifactor authentication (FIDO2 security keys or platform authenticators) enrolled to the specific device shipped, so a stolen password or a second operator on a KVM switch cannot complete login alone.
- **Verify device receipt against the identity record.** Require the worker to photograph the device serial number and confirm delivery at the address on file in identity documents, matching the practice [IC3's July 2025 advisory](#) recommends: ship only to addresses that match verified identification, and treat a request to ship elsewhere, a stated relative's address, a coworking space, a freight forwarder, as a red flag requiring escalation, not accommodation.
- **Fingerprint the network path, not just the login.** Impossible-travel and IP-reputation tooling should evaluate every session, not only the first one: compare geolocation against claimed residence, flag commercial VPN and residential-proxy exit nodes, and flag KVM-over-IP and remote-desktop signatures on a device that should be operated locally ([Spur research on remote worker fraud detection](#); [FBI advisory on residential proxy abuse](#)).
- **Baseline working hours against claimed time zone.** DPRK IT worker operations frequently work a shifted schedule (often described as a night shift local to the operator, appearing as normal daytime hours in the target country) to sustain the fiction of a co-located employee; a login pattern with no variance across weeks, or one that maps cleanly to a UTC+8/UTC+9 working day for a worker claiming U.S. residency, deserves review.

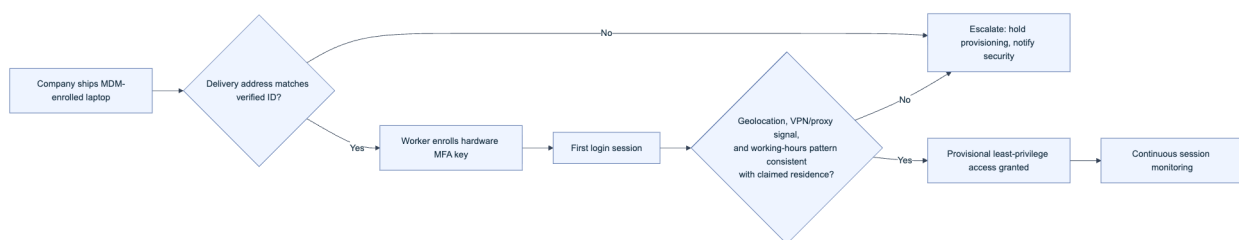


Figure 6. Device and network verification as a gate, not a one-time check. Each stage produces a signal that either escalates or allows the next stage, mirroring the KVM and laptop-farm pattern documented in the Chapman prosecution.

7.2 Access and Least Privilege for Remote Roles

Least privilege for a remote hire is not a policy statement, it is a provisioning default: grant the minimum system access needed for the first assignment, expand only on demonstrated need, and treat every grant as provisional until identity and behavior are independently confirmed. This

follows directly from **NIST SP 800-207**'s zero trust architecture model, which replaces one-time network perimeter trust with continuous, per-session verification and explicit least-privilege grants regardless of whether the requester is on a corporate LAN or remote.

Apply this concretely to a new remote engineering or IT hire:

Access tier	Default at day 1	Expansion trigger	Review cadence
Source code repositories	Read-only, single assigned repo	Manager approval + 30 days tenure	Quarterly
Production deploy credentials	None	Named approval, time-boxed, logged	Every grant
Secrets and key management systems	None	Role-specific, scoped to minimum secret set	Every grant
Customer or user PII (personally identifiable information) systems	None	Data protection officer or equivalent sign-off	Monthly
Internal communication (chat, wiki)	Standard channels only	N/A	N/A
VPN or private network access	Segmented VLAN for new hires	After device and identity re-verification	90 days

The **Skadden analysis of North Korean remote IT worker risk (June 2026)** recommends granting access “ideally on a provisional basis initially” precisely because pre-hire verification, however rigorous, cannot fully substitute for observed on-the-job behavior. Treat the first 30 to 90 days as a probationary access period with tighter logging and a lower threshold for review, not merely a probationary employment period on paper.

Segment access by trust boundary rather than by convenience. A remote contractor working on a single microservice does not need read access to the monorepo, and a distributed-team IT support role does not need standing admin rights to identity systems. Bidirectional role review matters here too: a semi-trusted role (an admin, a keeper of secrets, a build pipeline operator) that could plausibly abuse its own access in the *opposite* direction from its intended use, granting itself more privilege or exfiltrating what it can already read, deserves the same scrutiny as an external attacker's path. Log every grant, every elevation, and every credential issuance to a store the same team cannot unilaterally purge.

7.3 Communication and Data Handling

Communication channel choice is itself a signal. The **May 2022 State/Treasury/FBI joint advisory** lists a “preference for text or audio communication to avoid detection” and difficulty reaching a worker “in a timely manner, especially through videoconferencing” as recruitment-stage red flags,

and the same pattern persists post-hire: a remote employee who routinely declines camera-on meetings, insists on async text over voice, or requests migration of work discussion to a personal messaging app outside company logging is exhibiting the same evasion behavior in a different phase of the relationship.

Set explicit expectations at onboarding, not as a reaction to suspicion:

- **Mandate camera-on for scheduled 1:1s and team syncs**, with an documented, narrow exception process (medical, connectivity) that a manager, not the worker alone, approves.
- **Keep all work communication on company-controlled, logged channels**. Migrating substantive project discussion to personal WhatsApp, Telegram, or similar is a policy violation regardless of intent, and it is also exactly how a facilitator relays instructions from the actual operator to a front person, as described in the [KnowBe4 incident write-up](#).
- **Restrict data egress from managed devices**. Disable or monitor USB mass storage, personal cloud storage sync clients, and unmanaged email forwarding on any device with source code or customer data access; DLP (data loss prevention) tooling should alert on large or repeated exfiltration-shaped transfers, especially to personal cloud accounts or messaging apps.
- **Classify data before it reaches a distributed team member**. Not every remote hire needs the same data class; scope repository and document access by classification tier so a compromised or malicious low-tier account cannot reach high-sensitivity material by lateral movement alone.

8. Overseas Consultation and Distributed Teams

Overseas consultants and fully distributed teams multiply the attack surface Part 7 addresses for a single remote employee, because each additional jurisdiction adds identity ambiguity, payment complexity, and legal exposure that domestic remote work does not carry to the same degree.

8.1 Trust Boundaries and Compartmentalization

Treat every overseas engagement, whether a named individual contractor or a staffing vendor supplying personnel, as a distinct trust boundary with its own blast radius. [Google Threat Intelligence Group's 2025 reporting](#) documented a single DPRK operator running twelve different personas across European employers simultaneously, spanning claimed nationalities from Italy to Vietnam to the United States; a compartmentalized access model limits what any one of those twelve personas, if hired, could touch, and prevents a single compromised persona from becoming a pivot point into unrelated projects or teams.

Compartmentalization has three practical dimensions for a distributed engagement:

1. **Project-level isolation.** An overseas contractor engaged for one client project or one repository should not, by default, see credentials, code, or data belonging to a different project, even inside the same company. Multi-tenant access controls (separate namespaces, separate service accounts, separate secrets stores per project) enforce this technically rather than relying on the contractor's discretion.
2. **Vendor-of-vendor visibility.** A staffing vendor that itself subcontracts to individual developers, common in offshore development shops, breaks direct identity verification: the company verifies the vendor, not necessarily the specific person the vendor assigns. Contractually require the vendor to disclose the actual individual performing the work and to re-verify identity on any substitution, closing exactly the gap the **multi-defendant DOJ indictment covering 64 U.S. companies** exploited when North Korean operatives worked through layers of U.S.-based facilitators who fronted as the visible contractor.
3. **Need-to-know over convenience.** Resist granting an overseas team broad access "to move faster." The zero trust model in **NIST SP 800-207** applies with more force here, not less: distance and jurisdictional variance make in-person verification of a claim ("I need this to finish the sprint") harder to sanity-check informally, so the technical control has to do the work a hallway conversation would otherwise do.

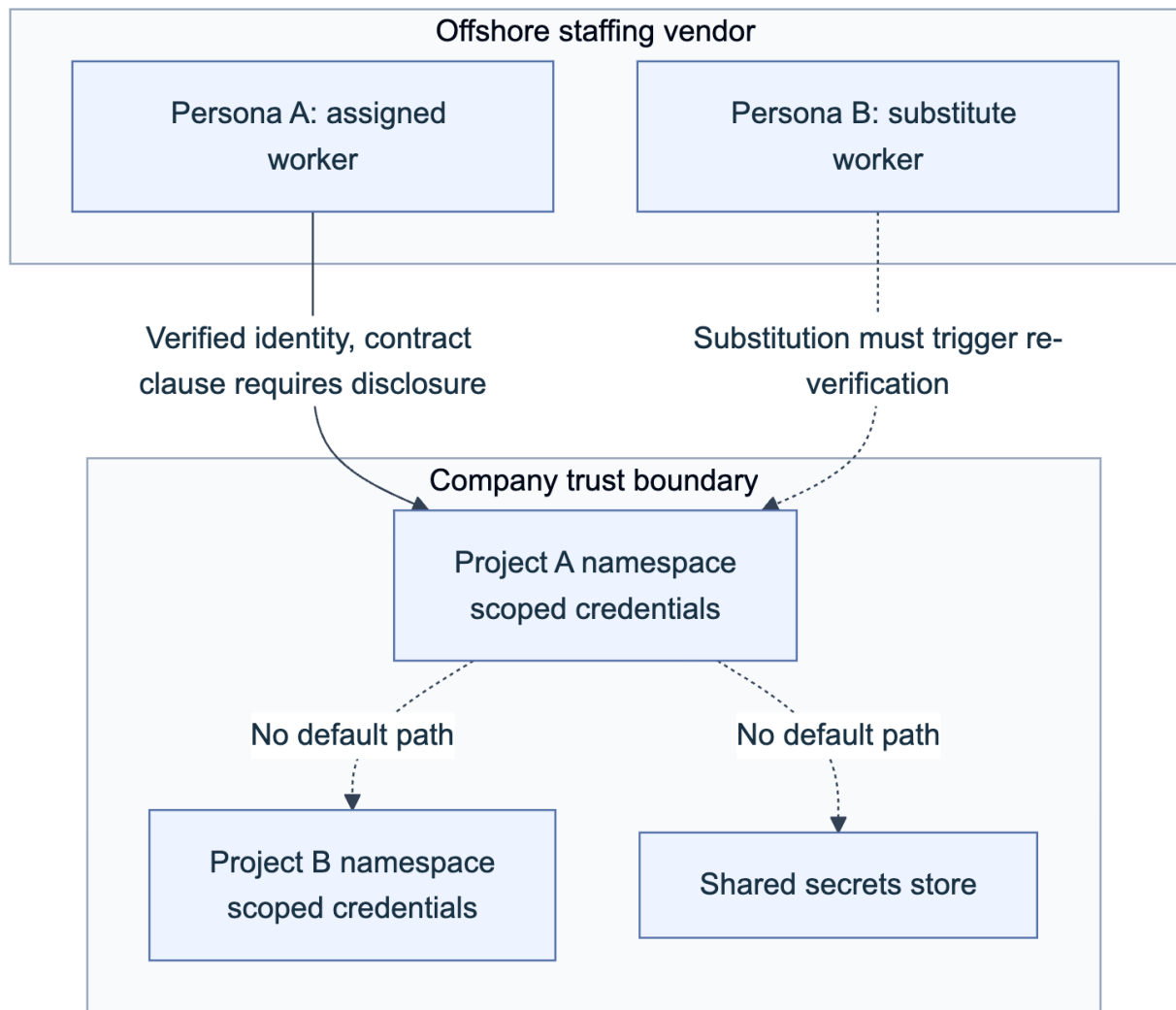


Figure 7. Compartmentalized access for an offshore vendor engagement. Project namespaces are isolated from each other and from the shared secrets store; any substitution of the assigned individual re-triggers verification rather than inheriting trust.

8.2 Payment and Identity Verification

Payment mechanics are one of the highest-signal indicators available post-hire, because DPRK IT worker schemes ultimately exist to generate revenue, and the [Treasury OFAC designations of July 2024](#) describe networks that generated nearly \$800 million in a single year by routing salaries through facilitators in the DPRK, Vietnam, Laos, and Spain who converted wages to cryptocurrency for transfer back to the regime. A Vietnam-based facilitator in that action alone converted roughly \$2.5 million into crypto for North Korean workers between mid-2023 and mid-2025.

Build payment and identity verification around these controls:

- **Match banking details to identity documents, every time.** Verify the name on the bank account against the name on the government ID and tax documentation before the first payment, not only at initial onboarding; re-verify on any change request.
- **Treat mid-engagement payment changes as an escalation trigger.** A request to redirect salary or invoice payment to a new account, a different country, or a cryptocurrency wallet

is one of the clearest indicators in the entire threat model. The IC3 advisory explicitly flags “frequent banking changes and requests for virtual currency payments” as warning signs (see Section 9.1 below for the full post-hire indicator set).

- **Screen payment destinations against sanctions lists.** Run OFAC’s Specially Designated Nationals (SDN) list and equivalent EU, UK, and UN sanctions lists against every payment destination for overseas contractors, and repeat the screening periodically, not only at contract signing, since designations change; the [Treasury press releases](#) documenting these networks are updated on a rolling basis as new facilitators are identified.
- **Prefer verifiable payment rails over informal ones.** Payroll run through a reputable Employer of Record (EOR) or payroll provider with its own KYC (know your customer) obligations adds an independent verification layer; direct peer-to-peer crypto payment to an individual contractor removes that layer entirely and should be treated as higher risk requiring additional identity assurance.
- **Reconcile headcount against payroll on a schedule.** The Skadden guidance recommends regular audits for “phantom” workers in payroll records, catching the case where a name remains on payroll after the actual work relationship should have ended, or where a facilitator inserted an unauthorized entry.

8.3 Contractual and Legal Considerations

Contracts for overseas consultants and distributed team members need to do more legal work than a standard domestic agreement, because they sit at the intersection of employment law, sanctions law, and data protection law across jurisdictions.

Employment classification. Misclassifying a long-term, integrated overseas worker as an independent contractor exposes the company to back taxes, statutory benefits claims, and in a growing number of jurisdictions, personal liability for company directors; roughly 30 percent of employers misclassify at least some workers, and exposure compounds with every jurisdiction added ([Toku’s crypto-industry misclassification analysis](#)). If the relationship looks like employment in substance (integrated into the team, working primarily for the company, taking day-to-day direction, engaged for an extended period), engage the worker through a compliant EOR or local entity rather than a bare contractor agreement, and revisit the classification if the scope of a “contractor” engagement quietly expands into a full-time role.

Audit and monitoring clauses. Every contractor and remote employee agreement should include explicit language permitting the company to audit system usage, log activity, and access company-issued devices for security purposes; the Skadden guidance identifies this as a prerequisite for effective insider threat response, since acting on monitoring data the contract did not authorize collecting creates its own legal exposure.

Sanctions and export control exposure. Engaging a worker who is, in fact, a DPRK national or is channeling wages to the DPRK creates potential liability under U.S. sanctions law independent of whether the company had actual knowledge, because OFAC's sanctions framework includes strict-liability elements for engaging with SDN-listed parties. Where the work involves controlled technology, export control regimes (ITAR, EAR) add a further layer: some technical data cannot legally be shared with nationals of certain countries regardless of physical location, so screening for nationality as well as physical location matters for sensitive engagements.

Data protection and residency. A distributed team spanning the EU, UK, or other jurisdictions with independent data protection regimes needs contract terms addressing lawful basis for cross-border data transfer, data residency commitments, and breach notification obligations that may run on a different clock than the company's home jurisdiction. Align these terms with the data classification tiers from Section 7.3 so that contractual protection and technical access control point at the same boundaries.

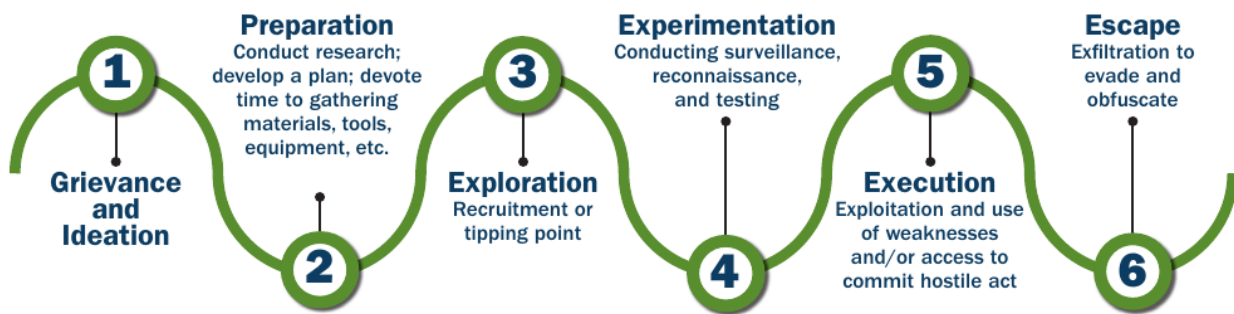
Termination and offboarding rights. Build immediate access-revocation rights into every overseas contractor agreement, without notice period, for cause tied to security policy violation or suspected fraud; a notice period appropriate for a routine contract termination is not appropriate for an active insider threat, and Section 10 covers the offboarding mechanics this clause enables.

9. After Hire: Post-Hire Behavior and Monitoring

Verification at hiring reduces but does not eliminate risk, so the program needs a second layer that watches behavior after access is granted. This chapter covers what to watch for and how to structure the watching.

9.1 Indicators After a Threat Actor Is Hired

Post-hire indicators cluster into four categories: identity inconsistency, access and network anomalies, communication evasion, and productivity or output anomalies. No single indicator is proof; the pattern across categories is what should trigger escalation, matching the multi-signal approach **Kraken's security team used to expose a North Korean applicant during a final-round interview** by combining a voice mismatch, an inability to answer city-of-residence questions, and a network of linked fake identities rather than any one red flag alone.

Figure 13. Progression of an Insider Toward a Malicious Incident⁵⁵

As illustrated by figure 13, the Progression of an Insider Toward a Malicious Incident, the

Figure. CISA's progression model is a detection aid, not a prediction engine. In this handbook's context, preparation, reconnaissance, access testing, execution, and exfiltration map to observable changes in account and device behavior; while the model's warning explicitly remains: the presence of one stage does not prove the later stages will occur. Source: *CISA Insider Threat Mitigation Guide*, Figure 13, public domain (U.S. government work).

Category	Indicator	Why it matters
Identity	Voice, appearance, or writing style shifts noticeably across sessions	Suggests multiple people sharing one "employee" identity, a documented DPRK IT worker pattern
Identity	Inability to answer spontaneous location-specific questions (nearby landmarks, local weather, time zone math)	Basic living-there knowledge a genuine resident has by default
Access	Logins from geographically implausible or rapidly shifting locations	Impossible-travel signature; may indicate KVM-over-IP or shared account use
Access	Consistent use of commercial VPN or residential proxy exit nodes	Common technique to mask true operating location
Access	Working hours that map cleanly to a DPRK/China-adjacent time zone rather than the claimed residence	Documented "night shift" pattern to sustain the daytime-presence fiction
Access	Requests for elevated privileges shortly after hire, beyond what the role requires	Consistent with a scripted pattern to reach source code or credentials fast
Communication	Persistent avoidance of camera-on meetings or voice calls	Documented recruitment-stage evasion behavior recurring post-hire
Communication	Push to move work discussion to unmonitored personal messaging apps	Removes the company's only visibility into coordination with a possible facilitator

Category	Indicator	Why it matters
Financial	Mid-engagement request to change payment destination, especially to a new country or a crypto wallet	Directly matches IC3 and OFAC-documented revenue-generation mechanics
Financial	Bank account name mismatched to identity documents	Sign of a facilitator receiving funds on the worker's behalf
Output	Work quality that does not match stated experience level, in either direction	Both a genuinely unqualified hire and a scripted "output pipeline" fed by an unseen second party can produce this signature
Output	Unusual data access patterns: bulk repository clones, broad document searches unrelated to assigned tasks	Consistent with the "data extortion" objective the IC3 July 2025 advisory specifically warns about

The KnowBe4 case is the clearest documented example of the access-anomaly category firing correctly: the company's endpoint detection flagged anomalous activity from a newly onboarded workstation roughly six minutes after the account received restricted, low-privilege access, and the security team revoked that access within twenty-five minutes ([SecurityWeek](#); [KnowBe4's own writeup](#)). No data was exfiltrated and no production system was reached, precisely because the least-privilege default from Section 7.2 meant the compromised account had almost nothing to lose access to.

9.2 Monitoring and Early Warning

Turn the indicator table into a running program, not a one-time checklist, by pairing behavioral awareness with technical telemetry.

Behavioral layer. Train managers and teammates, not just security staff, to notice and report the identity and communication indicators; CISA's [Insider Threat Mitigation Guide](#) frames an organization's own personnel as "an invaluable resource to observe behaviors of concern" and structures programs around four stages: define the threat, detect and identify it, assess it, and manage it. A manager who notices a direct report never turns on video and always requests text-only standups has produced a detection-stage signal even without security tooling involved.

Technical layer. Feed the access-category indicators into whatever SIEM (security information and event management) or UEBA (user and entity behavior analytics) capability the organization already runs: impossible-travel rules, VPN and residential-proxy attribution, device-fingerprint drift, and privilege-escalation alerts should all route to a queue someone actually reviews, not merely to a dashboard. The Incident Response Handbook (06) covers the tooling and triage workflow in depth; this handbook's contribution is ensuring hiring-and-vendor-specific signals (payment-destination changes, contract-substitution events, new-hire privilege spikes in the first 90 days) are wired into that same pipeline rather than sitting in HR or finance systems the security team never sees.

Escalation path. Define, in writing, who reviews a flagged pattern, what authority they have to suspend access provisionally while investigating, and how quickly a suspension can happen without waiting on a full investigation to conclude. The KnowBe4 timeline (detection to containment in under thirty minutes) is the target shape: fast, provisional, and reversible if the finding turns out to be a false positive, rather than slow and irreversible.

10. Ongoing Monitoring and Offboarding

Monitoring does not end when suspicion resolves one way or the other, and offboarding is a security control with its own failure modes, not an administrative afterthought.

10.1 Alignment with Employee Lifecycle Handbook

Ongoing monitoring and offboarding mechanics, the actual sequence of revoking badge access, disabling accounts, retrieving hardware, and rotating credentials, are owned by the Employee Lifecycle Security Handbook (03), and this handbook does not duplicate that mechanical detail. What this handbook adds is the hiring-and-vendor-specific triggers that should invoke those mechanics faster or more aggressively than a routine departure would warrant.

Three alignment points matter specifically for remote, overseas, and vendor-sourced personnel:

- **Contract substitution triggers immediate re-verification, not a lifecycle no-op.** If an offshore vendor swaps the individual performing the work, treat it as a new hire from a security-controls perspective (identity verification, provisional access, Section 8.1 compartmentalization reset), even though the vendor contract and the “position” continue unchanged. Standard lifecycle processes tuned for a single employee changing role do not automatically catch a personnel substitution behind a vendor relationship.
- **Sanctions or law-enforcement notice triggers emergency offboarding, bypassing standard notice periods.** The contractual termination-for-cause clause from Section 8.3 exists so that when a payment screening hit, an OFAC designation, or a law enforcement inquiry names a current vendor or contractor, the Employee Lifecycle Handbook’s offboarding checklist can execute immediately rather than waiting on a standard separation timeline.
- **Offshore and remote-hardware retrieval needs its own runbook step.** Physical device retrieval from an overseas or fully remote worker cannot rely on a same-day office badge-in; build device recovery, remote wipe confirmation, and credential rotation timing into the offboarding checklist explicitly for non-co-located personnel, since a delayed retrieval window is exactly the gap a malicious departing worker (or a facilitator, if the worker was never the real operator) can exploit.

10.2 Early Warning and Escalation

Early warning for a hire already past onboarding draws on the same monitoring described in Section 9.2, but the escalation stakes are different: a suspicious pattern in someone who already has months of accumulated access and trust needs a faster, more senior escalation path than a pattern flagged in week one.

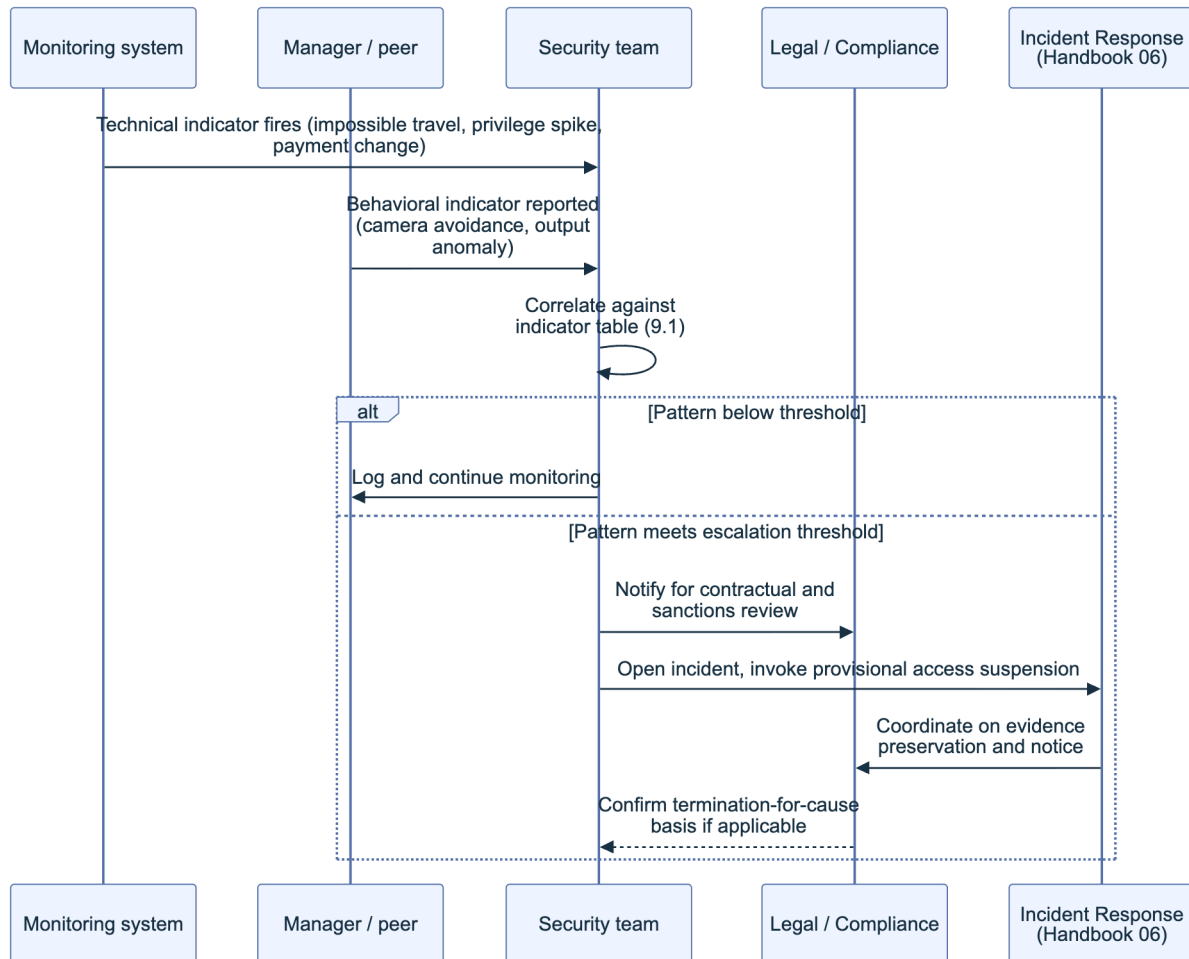


Figure 8. Escalation flow from a flagged indicator to a coordinated security, legal, and incident-response response. The provisional-suspension step (right branch) should not wait on legal sign-off to begin; it should trigger it.

Build a named escalation owner for hiring-and-vendor-linked security concerns specifically, someone who sits at the intersection of HR, security, and legal, so a flagged pattern does not stall in a queue while each function assumes another owns the next step. Document every escalation decision, including decisions not to act, since a pattern that resolves as a false positive today may become part of a stronger pattern when correlated with a later signal.

11. Mitigating Insider Threat Actors

The prior chapters cover detection; this chapter closes Part III with the structural changes that reduce how often detection is even necessary.

11.1 Hardening Hiring and Vendor Processes

Feed everything this part has covered back into the processes Part II defined, closing the loop rather than treating hiring and remote-work security as separate programs:

- **Institutionalize the Kraken-style verification interview technique** for any remote or overseas final-round candidate: spontaneous, unscripted questions about claimed location, government ID review on camera, and consistency checks across the full interview panel's independent observations, not a single interviewer's judgment.
- **Require vendor security addenda, not just service agreements**, covering the identity-disclosure, substitution-notification, and audit-rights clauses from Section 8.3 for every staffing and contracting vendor, and review vendor compliance with those clauses on a fixed cadence rather than only at renewal.
- **Screen sanctions exposure at the vendor level, not only the individual level.** The **Treasury designations** target facilitator entities as well as individuals; a vendor relationship that routes payments through a newly designated entity is a signal independent of anything the individual worker does.
- **Rotate and diversify sourcing channels** for high-risk roles (source-access engineering, treasury or funds-adjacent operations), since concentrated sourcing through a small number of platforms or referral chains is exactly what large-scale facilitator networks exploit at volume; the DOJ's multi-defendant indictments describe operations spanning dozens of companies sourced through a common small set of channels.

11.2 Organizational Defenses and Consequences

Beyond process, two organizational commitments determine whether the controls in this part actually function under pressure.

Fund the friction. Every control in this part, in-person or unobscured-video verification, provisional access, mandatory camera-on meetings, payment re-screening, adds hiring and onboarding friction that a growth-focused organization will be tempted to waive under deadline pressure. Treat waiver authority as a named, senior decision rather than a default a hiring manager can grant unilaterally; the **KnowBe4 and Kraken cases** both involved sophisticated, well-resourced security teams that still nearly missed the pattern, so an organization with weaker controls than either should assume its baseline detection rate is lower, not higher.

Build a no-blame reporting culture for false starts. A manager who raises a concern that turns out to be a false positive, an over-cautious HR reviewer who delays an offer for extra verification, should never face pushback for the delay; the cost asymmetry strongly favors over-escalation, since a missed indicator can cost a company data, funds, and regulatory exposure under strict-liability sanctions rules, while an unnecessary verification step costs, at most, a few days of hiring timeline.

Understand the consequence stack. An organization that inadvertently hires or facilitates a DPRK IT worker faces a compounding set of exposures beyond the immediate insider threat: sanctions liability under OFAC's strict-liability framework regardless of intent, potential export control exposure if controlled technical data was accessible, reputational damage on public disclosure, and the direct costs of incident response and remediation. The **nearly \$800 million** the Treasury Department attributes to these schemes in a single year is not merely a DPRK revenue statistic, it represents that many dollars' worth of individual company exposure events, most of which never make headlines. Treating the controls in this part as a compliance cost rather than a fund-preservation measure understates what is actually at stake.

Key controls for Part III

- Ship only MDM-managed hardware to addresses matching verified identity documents, and gate first access on device, identity, and network-consistency checks together, not any single one.
- Default every remote and overseas role to least-privilege, provisional access for the first 30 to 90 days, expanding only on named approval.
- Mandate camera-on meetings and company-controlled communication channels; treat migration to unmonitored personal messaging as a policy violation and a signal.
- Compartmentalize offshore vendor and consultant access by project, and contractually require identity disclosure and re-verification on any personnel substitution.
- Screen and re-screen payment destinations against OFAC and equivalent sanctions lists; treat mid-engagement payment-destination changes as a high-priority escalation trigger.
- Wire hiring-and-vendor-specific signals (privilege spikes, payment changes, contract substitutions) into the same monitoring pipeline the Incident Response Handbook (06) already operates, rather than leaving them siloed in HR or finance systems.
- Build emergency, notice-bypassing offboarding rights into every remote and overseas contract, and align execution with the Employee Lifecycle Handbook (03).

Part IV: Detection and Response

Hiring controls and remote-work hardening reduce the odds that a fraudulent hire or a compromised vendor ever reaches production systems, but no control set drives that risk to zero. This part covers what a team does once a red flag actually appears: how to read behavioral and technical indicators without over- or under-reacting, how to run a contained investigation that survives legal and public scrutiny, and how to fold a hiring-context malware or phishing event into the organization's broader incident response process. The playbooks below assume the reader already has, or is building, a general incident response capability; they add the hiring- and vendor-specific branches that a generic playbook does not cover.

12. Recognizing Potential Compromise

Recognition is the bottleneck, not response. Every publicly documented case of a Democratic People's Republic of Korea (DPRK, North Korea) information-technology worker infiltrating a software or Web3 company shows the same pattern: the warning signs existed for weeks or months before anyone escalated them ([KnowBe4, "How a North Korean Fake IT Worker Tried to Infiltrate Us," July 2024](#)). This chapter gives hiring managers, security teams, and IT administrators a shared vocabulary for what to watch and a clear rule for when a single odd signal becomes a case.

12.1 Behavioral and Technical Indicators

No single indicator proves a hire is fraudulent or a device is compromised. Genuine remote employees turn their camera off for privacy reasons, use a virtual private network (VPN) from a hotel, or hold a second job. What separates noise from signal is corroboration: two or three indicators from different categories, appearing together, on the same person. The May 2022 joint guidance from the U.S. State Department, Treasury, and FBI, later reinforced by dozens of Department of Justice (DOJ) cases, describes a consistent operating pattern for DPRK IT worker fraud ([State Department, "Guidance on the Democratic People's Republic of Korea Information Technology Workers," May 2022](#)): a fabricated or stolen identity used to pass a remote interview, a domestically hosted "laptop farm" that makes the login geography look legitimate, and revenue

funneled back through intermediaries to fund the regime’s weapons programs. Security researchers track the malware-delivery side of the same actor set under names such as Contagious Interview and Famous Chollima (Unit 42, “Contagious Interview: DPRK Threat Actors Lure Tech Industry Job Seekers,” 2024). The indicator categories below are drawn from these sources and should feed directly into the applicant-screening controls in Part II and the remote-work monitoring in Part III.

Read the table as a scoring aid, not a checklist to interrogate a single employee against. A hiring manager or security analyst who sees two or more rows firing for the same person should move to Section 12.2 rather than confront the individual directly.

Category	Indicator	Why it matters
Behavioral	Camera stays off, or video shows a static image or an AI-smoothed face that never quite matches the audio	Common workaround when the person on screen does not match the claimed identity
Behavioral	Repeatedly reschedules or refuses in-person meetings, notarized identity checks, or courier-delivered hardware	Physical presence risks breaking the cover identity
Behavioral	Asks to redirect payroll to a new account shortly after hire, or requests payment via cryptocurrency or a money-transfer service	Matches DOJ-documented mule-account and revenue-funneling patterns
Behavioral	Working hours are consistently offset from the claimed time zone, with unusually fast overnight task turnaround	Suggests work performed from a different time zone, sometimes by more than one person sharing an account
Behavioral	Avoids discussing personal history in detail, cites prior employers who cannot be reached, or gives biographical details that shift between interviews	Fabricated identity built on stolen or synthetic documents
Technical	A company laptop shows persistent inbound sessions from remote-access software such as AnyDesk, TeamViewer, or Chrome Remote Desktop	Signature of a “laptop farm”: the device sits at a domestic address while an operator abroad drives it, sometimes through a keyboard-video-mouse (KVM) switch
Technical	Login geolocation or autonomous system number (ASN) is inconsistent with the claimed residence, especially residential-proxy or virtual private server (VPS) ranges	Masks the operator’s true location

Category	Indicator	Why it matters
Technical	A shipped laptop never leaves a single receiving address after onboarding, regardless of the employee's claimed home city	Consistent with a paid facilitator hosting hardware for a remote operator
Technical	Device fingerprints, payment routing, or coding style overlap with another active or former employee elsewhere in the industry	DOJ and FBI cases describe individual DPRK IT workers holding several concurrent jobs
Technical	A code-contribution account has no verifiable history before the hire date, or commit timestamps and metadata are inconsistent with the claimed location	Digital footprint too shallow or misaligned for the claimed background

12.2 When to Escalate to Security or Legal

Escalation timing is a tradeoff between two failure modes: acting too early on a weak signal invites a wrongful-termination claim and a demoralized team, while waiting for certainty lets a compromised identity keep merge rights, secrets access, or payroll data for weeks longer than necessary. The National Institute of Standards and Technology's incident response guidance frames the first response phase as triage against defined severity criteria rather than a judgment call made in the moment ([NIST SP 800-61 Revision 3, "Incident Response Recommendations and Considerations for Cybersecurity Risk Management," April 2025](#)), and the same discipline applies to hiring-context signals. The rule this handbook recommends: a single indicator from the Section 12.1 table goes into a security or HR intake log for pattern tracking; two or more corroborating indicators, or any single indicator tied to fraud, identity theft, or credential misuse, triggers a formal security escalation the same day.

Once security opens a case, legal counsel is looped in before any user-facing action, not after. This preserves attorney involvement over the investigation's findings, keeps the organization defensible under employment law, and avoids an account suspension that later has to be walked back because it happened before the facts were nailed down. The Cybersecurity and Infrastructure Security Agency's insider threat guidance calls this a formalized, cross-functional intake process rather than an ad hoc one ([CISA, "Insider Threat Mitigation Guide"](#)). If the evidence points to criminal fraud, identity theft, or sanctions-adjacent revenue generation, which DPRK IT worker cases usually are, the case moves toward a law-enforcement liaison; see the Incident Response Handbook (06) for the formal notification process and the Employee Lifecycle Handbook (03) for the offboarding mechanics once containment is decided.

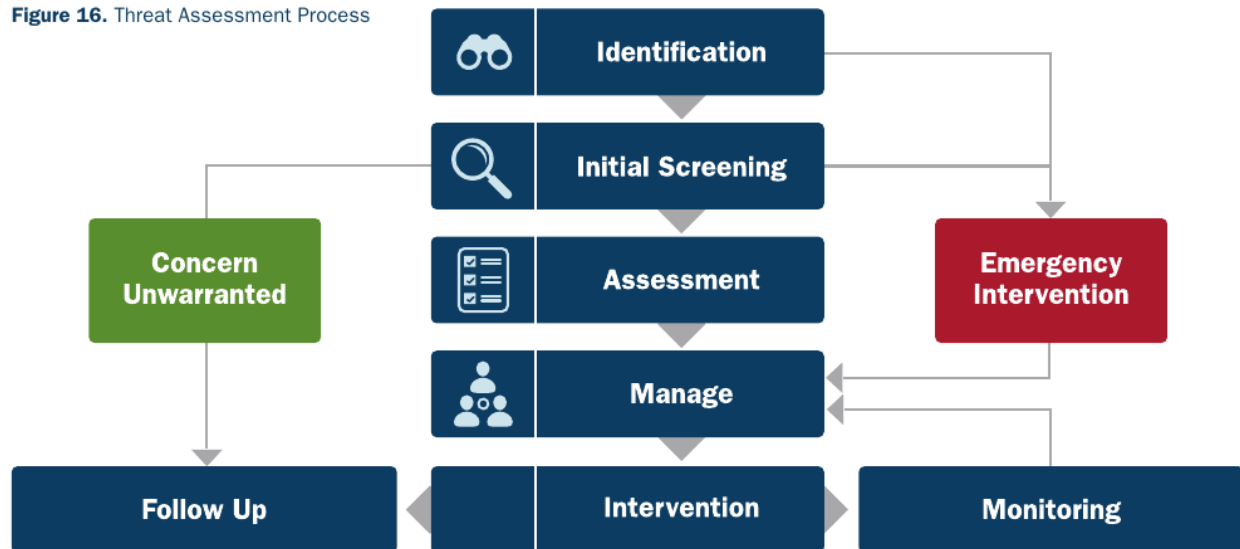
Figure 16. Threat Assessment Process

Figure. CISA's assessment flow preserves proportionality. Every report receives identification and initial screening; only supported concerns enter assessment and management; emergency facts branch to immediate intervention; and unwarranted concerns still receive documented follow-up. This is the operational safeguard against both ignoring corroborated risk and overreacting to a single ambiguous signal. Source: *CISA Insider Threat Mitigation Guide, Figure 16*, public domain (U.S. government work).

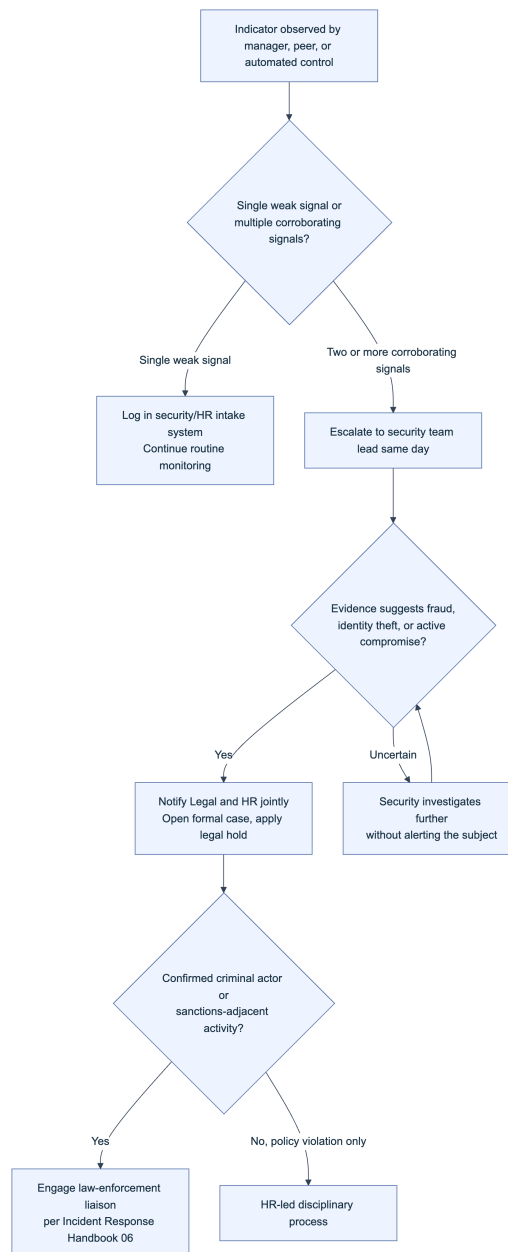


Figure 1. Escalation path from a single indicator to a formal case. Legal involvement precedes any account or employment action once fraud or compromise is suspected.

13. Response Playbook: Suspected Insider or Compromised Hire

Once a case is open, the goal shifts from detection to a contained, evidence-preserving investigation that can survive a lawsuit, a criminal referral, or a public disclosure. The three sections below sequence containment, coordination, and review into a repeatable playbook rather than a one-off scramble.

13.1 Containment and Evidence Preservation

The operating principle is contain without alerting until the legal hold and evidence capture are set. A subject who notices access changes before evidence is preserved may wipe a device, force-push over incriminating commits, or simply disappear, taking the forensic trail with them. Sequence matters: request a legal hold from counsel first, snapshot what you can before touching accounts (endpoint disk and memory image where policy and law allow, identity-provider and cloud audit logs, version-control history including any force-pushes or deleted branches, and package-registry publish logs if the person had publish rights), then suspend access in a single coordinated pass. Hash every forensic artifact at capture time and log a dual-custody chain, consistent with the evidence-handling expectations in NIST SP 800-61 Revision 3.

Because a compromised or malicious hire's blast radius extends to anything their credentials could reach, the suspension pass must be exhaustive, not just the obvious single-sign-on (SSO) account.

Containment checklist - Confirm legal hold is active before any account or device action. - Capture disk/memory image of the assigned device, if company-owned and policy permits. - Export identity-provider audit logs, VPN connection logs, and cloud IAM (identity and access management) activity for the account's full tenure. - Pull full version-control history for repositories the account touched, including force-pushed or deleted refs. - Suspend SSO sessions and revoke SSH/GPG keys, VPN certificates, and API tokens in one coordinated pass. - Rotate any secret the account could have read, not only ones it could write. - Revoke publish rights on any package registry, container registry, or content delivery network (CDN) pipeline the account could reach (cross-reference the CDN and Front-End Supply Chain Handbook, 01, if front-end deploy access was in scope). - Recover or remotely wipe company-issued hardware once evidence capture is confirmed complete.

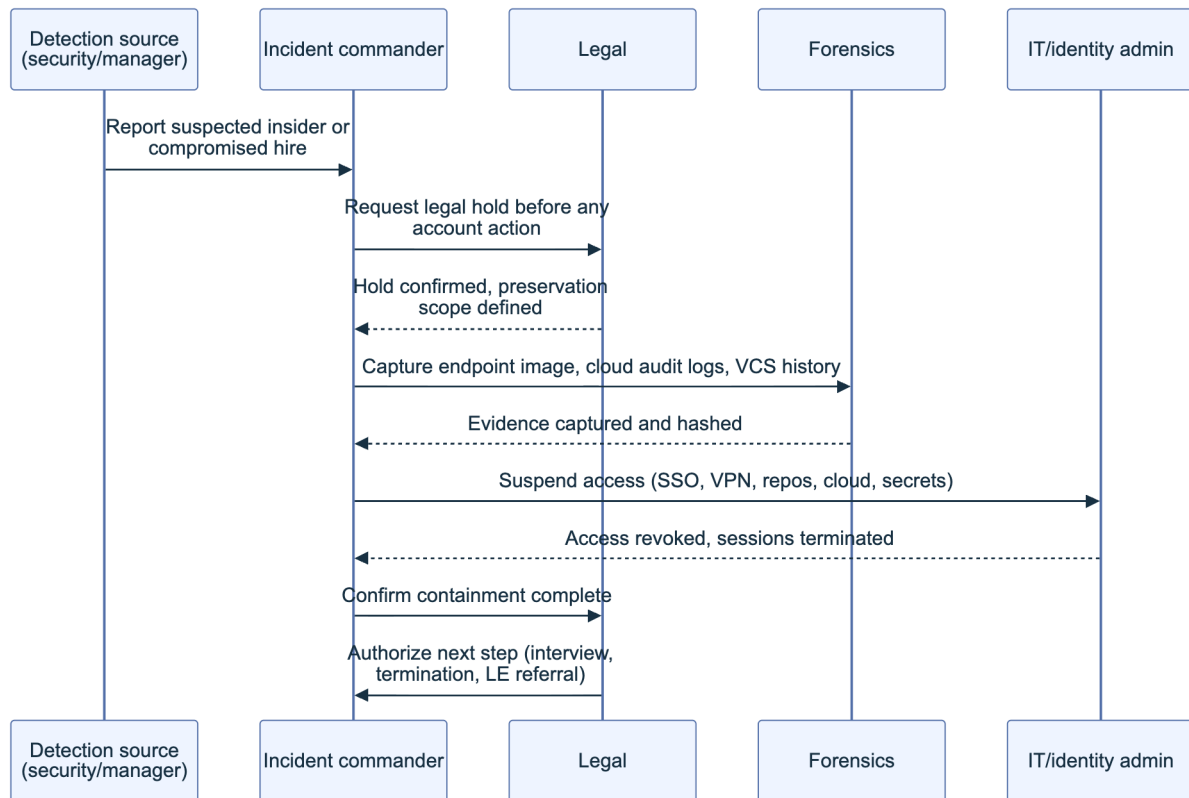


Figure 2. Containment sequence for a suspected insider or compromised hire. Evidence capture precedes or accompanies access suspension so the record is not created after the fact.

13.2 Communication and Coordination

Information about an active insider case spreads on a strict need-to-know basis. A wide internal announcement tips off the subject, invites speculation that can itself become a legal liability, and multiplies the number of people who might inadvertently leak the case externally before it is resolved. Keep the working group small and pre-designated rather than assembled ad hoc during the incident: a security lead acting as incident commander, one HR representative, one legal counsel, an IT/identity administrator for execution, and an executive sponsor who can authorize resourcing and external communication. This mirrors the cross-functional structure CISA recommends for a formal insider threat program, where security, HR, and legal share a single intake and case-tracking process instead of operating in silos.

External communication (to customers, investors, the press, or the subject's references) is gated behind Legal and the executive sponsor, never made unilaterally by whoever is closest to the case. If the case touches an international contractor or a cross-border employment arrangement, add the coordination steps from the Employee Lifecycle Handbook (03) covering jurisdiction-specific termination and data-handling requirements. No one on the core team makes promises to the subject about outcome, and no interview of the subject happens without HR and Legal present.

Task	Security	HR	Legal	IT/Identity Admin	Executive Sponsor
Initial triage and evidence capture	R/A	I	I	C	I
Legal hold and preservation scope	C	I	R/A	I	I
Access suspension and secret rotation	C	I	I	R/A	I
Subject interview	C	R/A	R/A	-	I
External communications	I	I	R/A	-	R/A
Law-enforcement referral	C	I	R/A	I	A

R = Responsible, A = Accountable, C = Consulted, I = Informed.

13.3 Post-Incident Review

Every case closes with a blameless post-incident review within two weeks, following the same “lessons learned” discipline NIST prescribes for the closing phase of incident response. The review is not about assigning fault to whoever conducted the interview or approved the hire; it is about measuring the control gap. Answer specifically: how did the individual pass reference and background checks, which control (behavioral, technical, or financial) first surfaced a corroborating signal, what was the dwell time between hire and detection, and which step in the containment playbook took longer than it should have. Feed the answers back into two places: the Section 12.1 indicator table, so newly observed patterns get added without over-fitting the whole program to one anecdote, and the hiring and hardening controls in Parts II and V, so a gap that let this case through gets closed structurally rather than just documented.

Post-incident report template - Timeline: first indicator observed, escalation, containment start, containment complete, case closed. - Dwell time: days between hire (or compromise) and detection; days between detection and containment. - Control gap: which pre-hire, technical, or process control should have caught this earlier. - Financial and operational impact: access held, systems touched, data or funds at risk. - Referral status: whether the case was referred to law enforcement, OFAC (Office of Foreign Assets Control), or another authority, and outcome if known. - Action items: specific, owned, dated changes to hiring, monitoring, or access controls. - Indicator table update: any new behavioral or technical signal to add to Section 12.1.

14. Response Playbook: Malware or Phishing Linked to Hire/Vendor

Some hiring- and vendor-context incidents are not primarily about identity fraud; they are a malware or phishing delivery mechanism that happens to arrive through the recruiting pipeline or a contractor relationship. This chapter is the arrival-vector annex to a general malware and phishing playbook, not a replacement for one.

14.1 Reference to Incident Response and Malware Playbooks

Handle the malware or credential-theft portion of these incidents through the organization's core incident response process, detailed in the Incident Response Handbook (06): isolate the affected host, preserve volatile evidence before it decays, extract indicators of compromise, and correlate them against known threat clusters before deciding on eradication and recovery. What this handbook adds is vector-specific context, because DPRK-nexus campaigns targeting hiring and vendor relationships use a small, well-documented set of malware families that a generic playbook will not name. Recognizing the family in play speeds triage: it tells the responder what persistence mechanism to expect, whether cryptocurrency wallet files were a likely target, and which threat-intelligence writeups to pull for indicators.

Campaign / malware	Attributed cluster	Typical delivery vector	Primary reference
BeaverTail (JavaScript stealer) and InvisibleFerret (Python backdoor)	Contagious Interview / Famous Chollima	Malicious npm or PyPI "coding assessment" repository sent to a candidate during a fake interview	Unit 42
TraderTraitor	Lazarus Group	Trojanized cryptocurrency trading or wallet-management application delivered to blockchain-adjacent staff or a vendor	CISA/FBI/Treasury Advisory AA22-108A
AppleJeus	Lazarus Group	Fake or trojanized crypto exchange and trading-platform installer	CISA Advisory AA21-048A
RustBucket / KANDYKORN	BlueNoroff	macOS malware delivered via a fake PDF viewer or "trading bot" package during a social-engineered contact with crypto-adjacent staff	Elastic Security Labs

A fast, high-consequence example ties this table to the vendor side of the chapter title directly. On February 21, 2025, attackers drained roughly \$1.5 billion in ether from Bybit's cold wallet by compromising a Safe{Wallet} developer's workstation and manipulating what the exchange's signers saw and approved in the multisig interface. The FBI publicly attributed the operation to

the TraderTraitor cluster days later. It began as a single compromised developer endpoint at a vendor, not a code-level flaw in the smart contracts themselves, which is exactly the seam this chapter exists to cover.

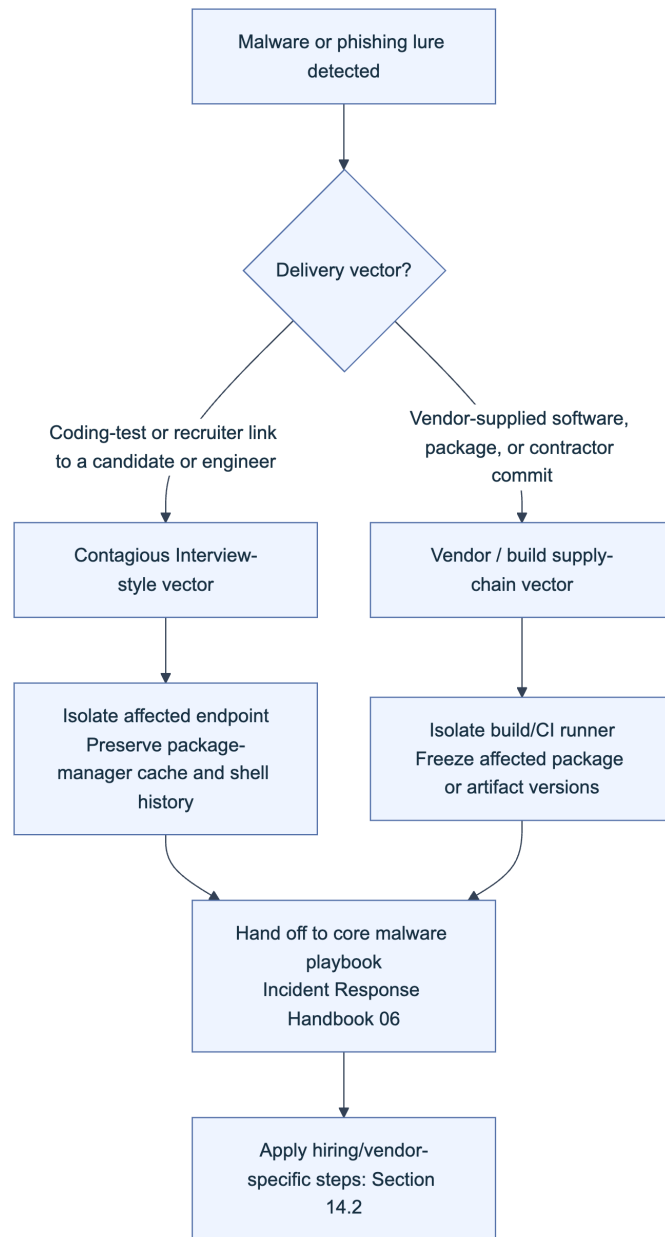


Figure 3. Triage split between candidate-facing and vendor-facing malware vectors, converging on the shared incident response process with a hiring/vendor-specific follow-on.

14.2 Specific Steps for Hiring and Vendor Context

Five additions distinguish a hiring- or vendor-linked malware case from a generic one. First, audit everything the individual or vendor touched retroactively, including work done during a trial period or an unpaid take-home assignment, since dwell time can predate the formal hire date. Second, revoke and rotate every credential ever issued to that identity, not only the ones still active, because DPRK IT worker cases repeatedly show access outliving a short or terminated

engagement. Third, treat take-home coding assessments and vendor-supplied installers as untrusted by default: run them in a disposable virtual machine or sandbox, never on a primary development machine with production credentials cached, which directly defeats the Contagious Interview delivery mechanism described above. Fourth, for a vendor-originated incident, invoke the security and incident-notification clause in the vendor contract and independently verify any rotation or patch the vendor claims rather than accepting their attestation at face value. Fifth, check whether the compromised identity had downstream publish rights to a public package registry or a CDN deployment pipeline; if it did, an isolated hiring incident becomes a customer-facing supply-chain incident with its own disclosure obligations, covered in the CDN and Front-End Supply Chain Handbook (01).

Step	Hire-specific action	Vendor-specific action
Scope the blast radius	Pull full commit and access history for the individual's entire tenure, including pre-hire trial work	Pull the vendor's access logs and any subcontractor accounts operating under the same contract
Credential rotation	Revoke every credential ever issued, including ones already deactivated by normal offboarding	Force rotation of shared secrets, API keys, and any federated identity the vendor used
Isolate the lure artifact	Quarantine the take-home assessment repository; never re-run it outside a sandbox	Quarantine the vendor-supplied package or installer; pin and audit the last known-good version
Independent verification	Confirm via a second engineer that no artifact from the assessment reached a shared or production system	Do not accept the vendor's self-reported remediation; re-scan the delivered artifact independently
Disclosure check	Determine if any customer-facing system was reachable from the individual's access	Determine if the vendor's compromise reached your CDN, package registry, or build pipeline (Handbook 01)

```
# Example credential-revocation sweep for a departing or suspect identity.
# Run from an admin account on a fresh, out-of-band session; placeholders
# stand in for the actual org, user, token, and key identifiers.

gh api -X DELETE /orgs/ORG_NAME/members/SUSPECT_USER           # remove GitHub org access
gh api -X GET  /orgs/ORG_NAME/actions/secrets                  # audit CI secrets they
                                                                # could read
npm token revoke <TOKEN_ID> --registry=https://registry.npmjs.org/
aws iam list-access-keys --user-name SUSPECT_USER
aws iam update-access-key --access-key-id <KEY_ID> --status Inactive --user-name SUSPECT_USER
# Rotate anything the identity could have read, not only what it could write
```

Key controls for Part 4

- Score behavioral and technical indicators together; escalate on corroboration, not on a single ambiguous signal.

- Bring Legal in before any account or employment action once fraud or compromise is suspected, not after.
- Sequence containment as legal hold, then evidence capture, then a single coordinated access-suspension pass.
- Keep the incident core team small and need-to-know; gate external communications behind Legal and the executive sponsor.
- Run a blameless post-incident review within two weeks and feed findings back into the Section 12.1 indicator table and the hiring controls in Parts II and V.
- Treat take-home assessments and vendor-supplied artifacts as untrusted; sandbox them and independently verify vendor remediation claims.
- Check downstream publish rights (package registries, CDN pipelines) whenever a hiring or vendor incident is contained, since that determines whether it stays internal or becomes a supply-chain disclosure.

Part V: Hardening and Best Practices

Parts II through IV gave an organization the individual controls: how to source and interview, how to harden a remote role, how to detect a compromised hire, and how to respond once one is found. Part 5 turns those controls into a program: a named governance structure that owns them, a training curriculum that keeps the people running them current, policy documents that survive staff turnover, and a discipline for tracking the advisories that keep changing the threat picture. Nothing here replaces the mechanics in Parts II to IV; it is the scaffolding that keeps those mechanics from decaying into a one-time response to whichever incident prompted them.

15. Organizational Defenses

A control with no owner erodes the moment the person who built it moves teams. This chapter sets the governance, lifecycle, technical baseline, and collaboration structure that keeps the Democratic People's Republic of Korea (DPRK) IT worker and broader insider-threat controls from this handbook operating past their first year.

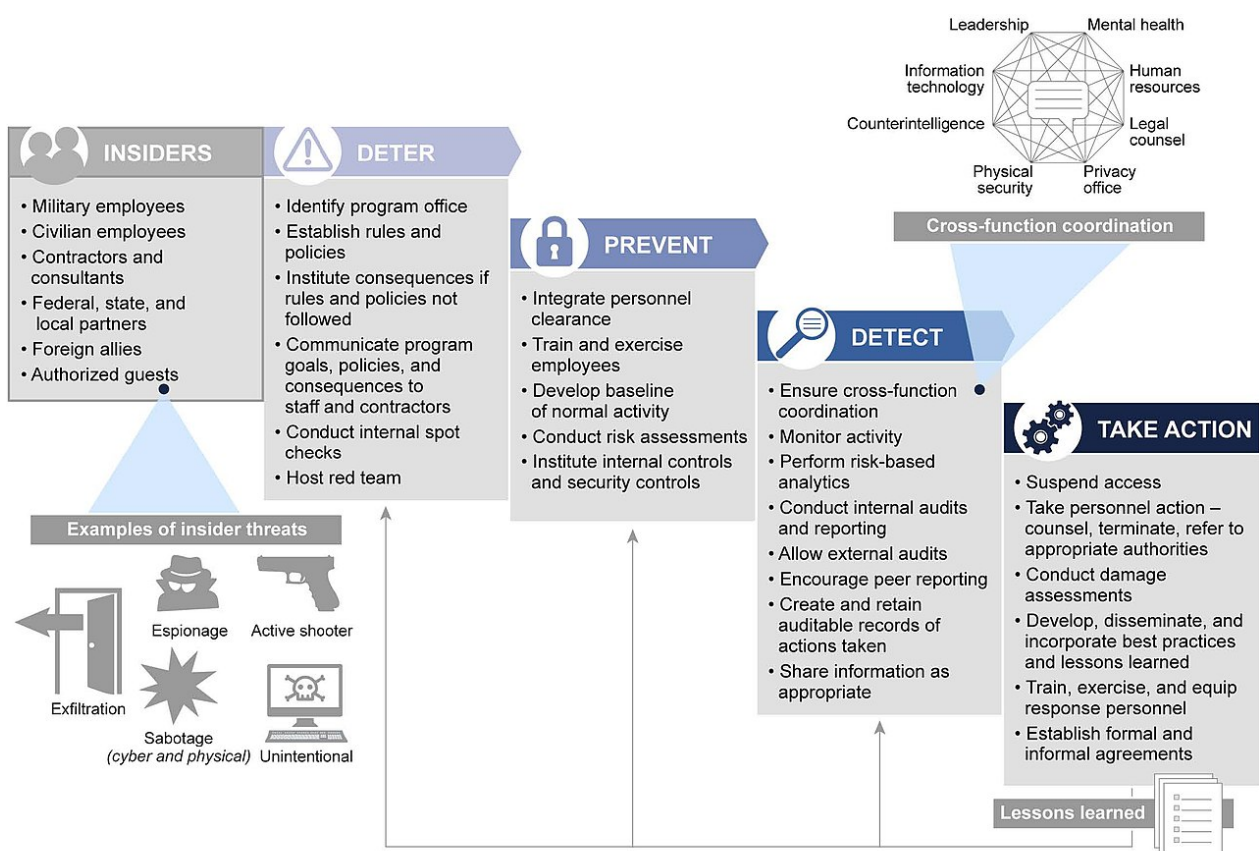
15.1 Program Governance: From Ad Hoc Response to a Named Function

Most organizations discover this threat model reactively: a suspicious hire, a near miss like the one KnowBe4 disclosed publicly, or a Rewards for Justice notice arrives, a task force forms, and the task force disbands once the immediate question is answered. That pattern leaves no standing owner for the next hire.

The [Cybersecurity and Infrastructure Security Agency \(CISA\)](#) publishes two documents that, read together, describe what a standing program looks like. The [Insider Threat Mitigation Guide](#) (November 2020) defines the operating model a program runs day to day: Define the threat for the organization, Detect and Identify concerning behavior, Assess it, and Manage it toward resolution, the same four-stage cycle referenced against a specific case in Part III Section 9.2. A newer CISA release, [Assembling a Multi-Disciplinary Insider Threat Management Team](#) (January

28, 2026), sits one level above that: it structures how to build the team that runs the four-stage cycle, using a Plan, Organize, Execute, and Maintain (POEM) lifecycle and explicitly naming security, human resources (HR), legal, information technology (IT), and operations as the disciplines that must sit at the same table.

The **National Insider Threat Task Force (NITTF)**'s **Insider Threat Program Maturity Framework** (November 1, 2018) adds a maturity lens across six focus areas: senior official and program leadership, program personnel, employee training and awareness, access to information, monitoring user activity, and information integration, analysis, and response. It was written for U.S. federal agencies, but a crypto-native company can map its own program against the same six areas to see where it is still ad hoc.



Source: GAO analysis of Department of Defense (DOD), U.S. government, and private-sector guidance and reports. | GAO-15-544

Figure. A U.S. Government Accountability Office breakdown of the phases and key elements a mature insider-threat program incorporates, the same kind of structured lifecycle the CISA POEM model and the NITTF maturity framework describe for a hiring-and-vendor program built on this handbook. Source: U.S. GAO, GAO-15-544, public domain (U.S. federal government work).

For the hiring-and-vendor context specifically, name a program lead who sits above any single hiring decision, and give that lead standing (not incident-triggered) representation from HR or talent acquisition, security, legal or compliance, finance or payroll (payment-destination changes are one of the strongest indicators in Part III Section 9.1), and IT (device and access provisioning). This is the same escalation triangle Part III Section 10.2 describes for a live incident, made permanent rather than assembled fresh each time.

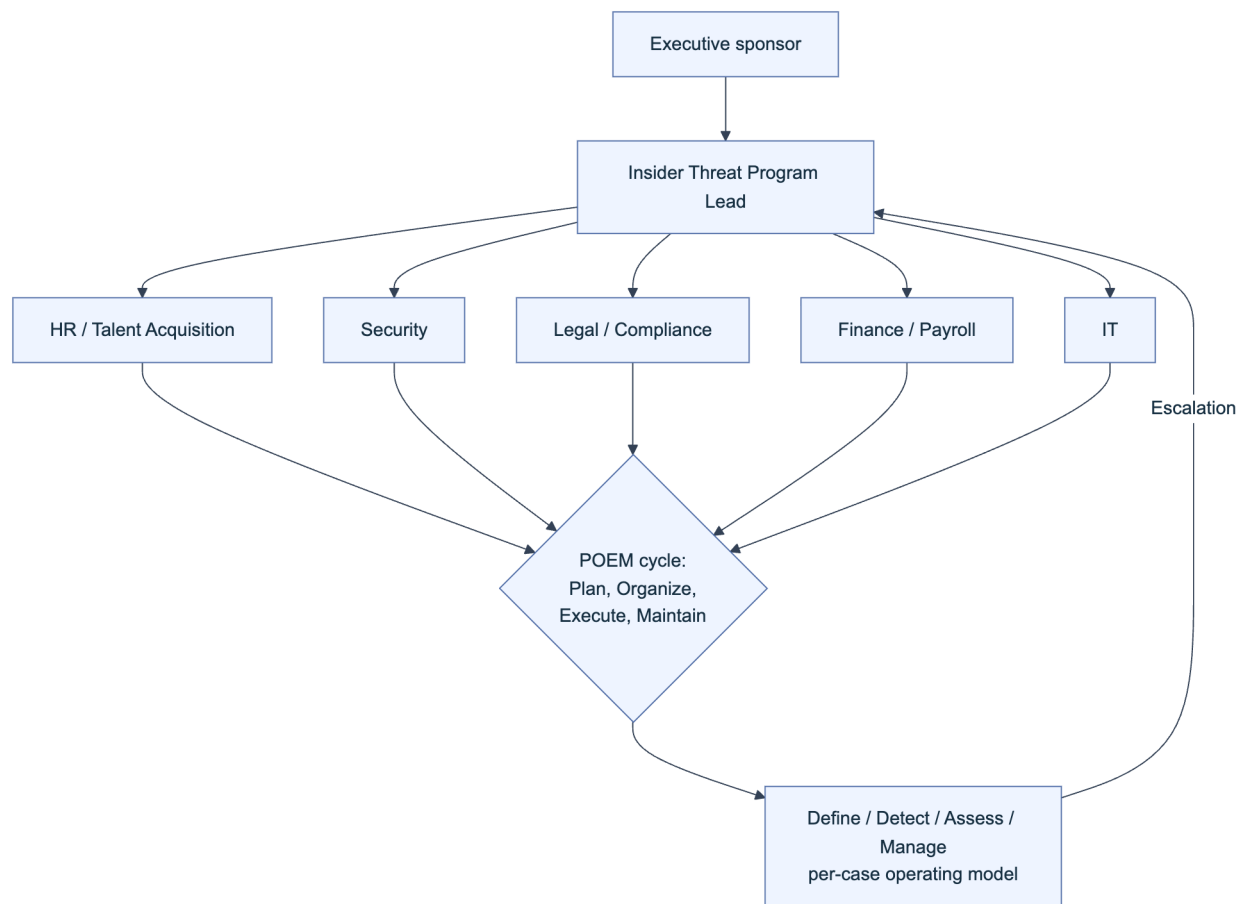


Figure 9. Standing program governance for hiring and vendor insider-threat risk. The POEM lifecycle (outer) builds and maintains the team; the Define/Detect/Assess/Manage cycle (inner) is what that team runs against each flagged case.

15.2 Defense in Depth Across the Hiring-to-Offboarding Lifecycle

No single control in this handbook is sufficient against a well-resourced, state-linked operator; the **Skadden** analysis cited in Part III explicitly frames pre-hire verification as necessary but not sufficient. What makes the program resilient is that each lifecycle stage's control draws on an independent signal from a different owner, so a miss at one stage does not cascade automatically into a miss at the next.

Lifecycle stage	Primary control	Independent backstop	Owner	Handbook reference
Sourcing	Controlled channel distribution	Red-flag review at application intake	HR / Talent	Part II, Section 3
Interview	Identity verification, camera-on requirement	Cross-panel consistency review	Hiring manager + HR	Part II, Section 4
Vendor selection	Sanctions and due-diligence screening	Contract audit-rights clause	Procurement / Legal	Part II, Section 5

Lifecycle stage	Primary control	Independent backstop	Owner	Handbook reference
Remote onboarding	Managed device, hardware multifactor authentication (MFA), address-to-identity match	Provisional least-privilege access	IT / Security	Part III, Section 7
Ongoing employment	Behavioral and technical monitoring	Escalation triangle	Security / Manager	Part III, Sections 9 to 10
Payment	Sanctions screening, verifiable payment rails	Mid-engagement re-screening	Finance	Part III, Section 8.2
Offboarding	Notice-bypassing termination clause	Emergency device and credential revocation runbook	HR / IT / Security, aligned with Handbook 03	Part III, Section 10.1

The backstop column is deliberately drawn from a different data source than the primary control it backs up: interview identity checks are backed by manager-visible payment behavior weeks or months later, not by a second identity check. A layered program treats that independence as the point, not a redundancy to be trimmed for efficiency.

15.3 Technical Control Baseline Tied to Personnel Risk

NIST Special Publication 800-53 Revision 5 gives the control-catalog anchor most auditors and frameworks will expect this program to map against. PS-3 (Personnel Screening) requires screening before granting system access and rescreening on a schedule tied to the position's risk designation; PS-7 (External Personnel Security) extends the same obligation to contractors, vendor-supplied staff, and other non-employees, which is the exact population Part II Section 5 and Part III Section 8 cover.

Beyond the screening baseline, Google Threat Intelligence Group and Mandiant's guidance on the threat cluster it tracks as UNC5267 ("UNC" designates an uncategorized cluster in Mandiant's naming convention, later attributed with high confidence to DPRK IT worker operations) gives a concrete technical baseline that goes beyond identity screening into runtime monitoring of the managed device itself:

Technical indicator	What it signals	Response
Multiple remote-administration tools on one endpoint (AnyDesk, TeamViewer, RustDesk, Chrome Remote Desktop, GoToRemote/LogMeIn)	Possible laptop-farm or KVM-relayed operation	Alert, restrict installation via device policy
Mouse-jiggler or activity-simulation software (for example, Caffeine)	Sustaining apparent activity across multiple simultaneous jobs	Alert, manual review

Technical indicator	What it signals	Response
Egress through high-risk commercial VPN providers (Astrill VPN named specifically in Mandiant's reporting)	Location masking inconsistent with claimed residence	Flag session, cross-check against Part III Section 7.1's geolocation controls
IP-based keyboard-video-mouse (KVM) device signatures	Remote operator driving a device that should be operated locally	Escalate immediately, tie to Section 15.2's onboarding backstop
Hardware-bound MFA absent or bypassed	Credential or device sharing across operators	Block access, force re-enrollment

Feed each hit into the same Security Information and Event Management (SIEM) or User and Entity Behavior Analytics (UEBA) pipeline Part III Section 9.2 describes, rather than standing up a parallel detection stack specific to this threat model; duplication is how detection logic silently drifts out of date.

15.4 Information Sharing and Industry Collaboration

No single company sees the full pattern. Google Threat Intelligence Group's tracking of a single operator running a dozen simultaneous personas across different employers, cited in Part III Section 8.1, only becomes visible in aggregate across organizations, not from one company's hiring pipeline in isolation.

Route confirmed or strongly suspected cases to the FBI's [Internet Crime Complaint Center \(IC3\)](#) and, for cases with a plausible link to sanctions evasion or a named facilitator network, to the [Rewards for Justice DPRK IT worker program](#), which as of this writing offers rewards up to five million dollars for information disrupting these financial mechanisms through a Tor-based tips channel. Financial-sector organizations already routing phishing and fraud indicators through an Information Sharing and Analysis Center (ISAC) should extend that same channel to hiring-fraud indicators; crypto-native organizations without an existing ISAC relationship should build one, whether through a sector consortium or a bilateral arrangement with a security vendor's threat intelligence service, since this is precisely the kind of cross-company pattern that a single security team cannot reconstruct alone. Treat a public post-mortem like KnowBe4's as a model worth emulating rather than a liability to avoid: converting one company's near miss into another company's detection rule is the actual mechanism by which this defense improves industry-wide.

16. Training for Hiring Managers and HR

Controls only work if the people executing them recognize the pattern in front of them. This chapter builds the curriculum, cadence, and measurement discipline that keeps that recognition current.

16.1 Curriculum Design by Role

A single “watch out for North Korean IT workers” briefing under-trains the people who actually touch identity documents and over-trains people who never see a resume. Split the curriculum by the decision each role actually makes.

Audience	Core competency	Format	Primary source material
Recruiters / sourcing	Channel hygiene, resume-pattern red flags (reused text, geography-versus-university mismatches)	E-learning module plus live workshop	ASIS International, “Recruitment Red Flags: Spotting DPRK IT Remote Workers” (May 2025); IC3 PSA250723-4
Hiring managers / interview panel	Spontaneous consistency questioning, camera-on enforcement	Live role-play and tabletop drills	Part II, Section 4; Part III, Section 9.1 (Kraken case)
HR / People Operations	Address-to-identity verification, payment-change escalation, employer-of-record versus direct-contractor risk	E-learning plus quarterly refresher	Part III, Sections 8.2 to 8.3
IT / Security	Detecting the technical indicators in Section 15.3	Hands-on lab against real endpoint detection and response (EDR) or UEBA tooling	Section 15.3; Google Threat Intelligence Group
Finance / Payroll	Sanctions-list re-screening cadence, phantom-worker reconciliation	E-learning plus audit checklist	Part III, Section 8.2
Legal / Compliance	Strict-liability sanctions exposure, contract clause enforcement	Briefing plus annual legal update	Part III, Section 8.3

16.2 Delivery Cadence and Simulated-Candidate Drills

Deliver role-specific training within the first thirty days for anyone newly assigned to a hiring, vendor-management, or onboarding function, then refresh quarterly for high-exposure roles (recruiters and hiring managers for engineering, treasury, or other source-access positions) and annually for lower-exposure roles. The Defense Counterintelligence and Security Agency’s **Center for Development of Security Excellence (CDSE)** offers a useful external benchmark even for organizations with no federal obligation to use it: its Insider Threat Awareness course and its Insider Threat Program for Industry Curriculum (INT333.CU) demonstrate a defensible minimum training structure that a program can point to when justifying budget for its own curriculum.

Borrow the phishing-simulation model that security-awareness programs already use broadly and apply it to interviews: run a scripted mock candidate, played by a colleague or a red-team contractor, who exhibits known indicators, evasive camera behavior, an inability to answer a

spontaneous question about a claimed city, an inconsistency between stated and verified education, and measure whether the panel catches it. This generalizes the real detections at Kraken and KnowBe4 (Part III, Section 9.1) into a repeatable exercise rather than treating them as historical anecdotes. [Google Threat Intelligence Group's guidance](#) additionally recommends periodic mandatory camera-on spot checks with remote employees already on staff; schedule these on the same recurring calendar as the refresher training so neither becomes an afterthought.

16.3 Measuring Effectiveness

Untested training is a compliance artifact, not a working control. Track a small set of metrics and route them back to the governance function in Section 15.1: the catch rate on simulated-candidate drills across successive rounds, time-to-escalation on drills measured against KnowBe4's roughly twenty-five-minute real-world containment window as an aspirational floor (Part III, Section 9.1), the percentage of the trained population current on its refresher cadence, and the count of near-miss reports filed. A rising near-miss count is a positive signal in a mature program, not a negative one: it means the no-blame reporting culture Part III Section 11.2 calls for is functioning, and people are reporting uncertainty rather than suppressing it. When a specific panel or team underperforms on a drill, assign that team a targeted refresher immediately rather than waiting for its scheduled annual session; a fixed calendar should be the floor for training frequency, not the ceiling.

17. Policy Templates and Checklist

Verbal expectations do not survive a reorganization or a founder's departure. This chapter turns Parts II through IV, and the program structure in Chapter 15, into documents an organization can hand to a new hire, an auditor, or outside counsel.

17.1 Core Policy Documents and a Template Clause

Five documents cover the ground this handbook has established, each mapped to the control it operationalizes and, where applicable, the NIST 800-53 control family it satisfies:

Policy document	Maps to	Satisfies
Remote and Overseas Hiring Identity Verification Policy	Part II, Section 4.2	PS-3
Vendor and Contractor Security Addendum	Part II, Section 5.2; Part III, Section 8.3	PS-7
Insider Threat Response and Escalation Policy	Part III, Sections 9 to 10; Handbook 06	NITTF focus area 6 (integration, analysis, response)
Acceptable Communication Channel Policy	Part III, Section 7.3	NITTF focus area 5 (monitoring user activity)
Payment and Banking Change-Control Policy	Part III, Section 8.2	Sanctions and anti-money-laundering compliance

The [SANS Institute Security Policy Project](#) provides a widely used free structure for drafting policy documents (purpose, scope, policy statement, enforcement, definitions); apply that same structure here rather than inventing a new format per document. A payment change-control clause, drawn from this handbook's own guidance rather than any specific organization's document, illustrates the pattern:

POLICY: Payment and Banking Change-Control**PURPOSE**

Prevent unverified redirection of contractor or employee payment destinations, a documented mechanism in DPRK IT worker revenue schemes (see IC3 PSA250723-4; OFAC designations, July 2024 onward).

SCOPE

All remote, overseas, and vendor-sourced personnel receiving payment from the organization.

POLICY STATEMENT

1. Any request to change a payment destination (bank account, country, or cryptocurrency wallet) MUST be verified against government-issued identification on file before execution.
2. Requests to redirect payment to a new country, a third party, or a cryptocurrency wallet trigger MANDATORY escalation to the Insider Threat Program Lead (Section 15.1) before any change is executed.
3. No single approver may execute a payment-destination change without independent verification by a second reviewer.
4. All payment destinations are screened against OFAC's Specially Designated Nationals list and equivalent sanctions lists at initial setup and re-screened on [quarterly] cadence.

ENFORCEMENT

Violations are reviewed under the Insider Threat Response and Escalation Policy.

17.2 Program Implementation Checklist

This checklist stands up or audits the program as a whole; it is distinct from Appendix C's per-hire operational checklist, which a hiring manager runs against a single requisition. Run this checklist once to launch the program and annually thereafter.

Governance

- ☐ Named Insider Threat Program Lead with standing authority to suspend access provisionally (Section 15.1)
- ☐ Multi-disciplinary team seated: HR, Security, Legal, Finance, IT (Section 15.1)
- ☐ Program mapped against the NITTF's six maturity focus areas, with gaps documented

Technical

- ☐ SIEM/UEBA rules deployed for the Section 15.3 technical indicator baseline
- ☐ PS-3 and PS-7 screening and rescreening cadence documented and enforced
- ☐ Escalation triangle (Part III, Section 10.2) tested against a tabletop scenario in the past twelve months

Legal and Policy

- ☐ All five Section 17.1 policy documents drafted, legally reviewed, and published
- ☐ Vendor security addenda executed with every active staffing and contracting vendor
- ☐ Notice-bypassing termination-for-cause clauses present in all overseas and remote contracts

Training

- ☐ Role-specific curriculum from Section 16.1 assigned to every relevant role
- ☐ At least one simulated-candidate drill run in the past twelve months, with results logged
- ☐ Near-miss reporting channel published and no-blame policy communicated

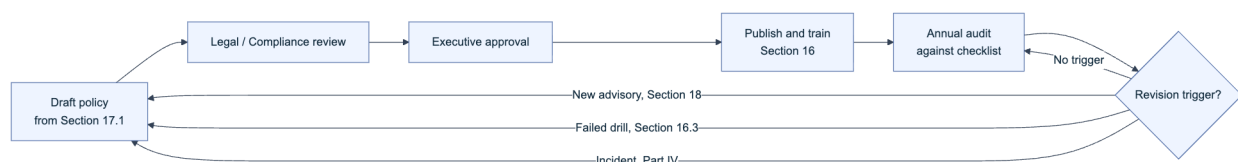


Figure 10. Policy lifecycle. A published policy is never final; a new advisory, a failed training drill, or a live incident all route back to the drafting stage rather than accumulating as unincorporated exceptions.

18. References to External Advisories and Resources

This chapter is a working reading list for the program built in this Part, organized by function rather than alphabetically. It is not the handbook's full bibliography; that lives in Appendix D. What belongs here is the smaller set of sources a program lead should track on an ongoing basis.

18.1 Primary Government and Law Enforcement Advisories

Source	Document	Date	Covers
FBI / IC3	PSA250723-4, North Korean IT Worker Threats to U.S. Businesses	July 23, 2025	Updated mitigation list, reporting instructions
FBI / IC3	PSA250123, North Korean IT Workers Conducting Data Extortion	January 23, 2025	Escalation from access fraud to extortion
U.S. State Department, FBI, and allied governments (Japan, Canada, Germany, Australia, UK, Republic of Korea)	Alert to Countries, Companies, and Other Entities Regarding North Korean IT Workers	July 31, 2026	Coordinated multinational warning, AI-enabled impersonation tactics
U.S. Treasury, Office of Foreign Assets Control (OFAC)	Sanctions designations on DPRK IT worker facilitator networks	Rolling, from July 2024	Screening targets for Section 15.4 and 17.1 payment controls
U.S. Department of Justice (DOJ)	Multi-defendant indictment and sentencing press releases	Rolling	Prosecutorial precedent and case-level detail
U.S. Department of State, Rewards for Justice	Reward offer for information on North Korean IT companies, IT workers, and related money laundering	Ongoing	Reporting incentive and secure tip channel

18.2 Standards, Frameworks, and Threat Intelligence Resources

Source	Document	Covers
NIST	SP 800-53 Revision 5, controls PS-3 and PS-7	Personnel and external-personnel screening control catalog
NIST	SP 800-207	Zero trust architecture underlying Part III's access model
CISA	Insider Threat Mitigation Guide	Define/Detect/Assess/Manage operating model
CISA	Assembling a Multi-Disciplinary Insider Threat Management Team	POEM team-building framework (Section 15.1)

Source	Document	Covers
NITTF / Office of the Director of National Intelligence	Insider Threat Program Maturity Framework	Six-focus-area maturity model
ASIS International	"Recruitment Red Flags: Spotting DPRK IT Remote Workers"	Recruitment-stage indicator guidance
Google Threat Intelligence Group / Mandiant	"Staying a Step Ahead: Mitigating the DPRK IT Worker Threat"	UNC5267 technical detection indicators
Mandiant	M-Trends 2026	Dwell-time and broader threat-landscape context
DCSA / CDSE	Insider Threat training curriculum	External training benchmark (Section 16.2)
SANS Institute	Security Policy Project	Policy-drafting structure (Section 17.1)

18.3 Building an Advisory-Monitoring Practice

Three separate FBI/IC3 public service announcements and one coordinated multinational joint alert landed inside roughly eighteen months through mid-2026 alone; a handbook chapter read once at program launch is stale within a year. Treat advisory monitoring as an assigned, recurring responsibility rather than a one-time read.

Name an owner, typically the Insider Threat Program Lead from Section 15.1, responsible for subscribing to IC3 industry alerts, CISA advisories, and OFAC recent-actions notifications. Set a fixed triage cadence (monthly is reasonable for routine updates) with an immediate ad hoc review triggered by any newly named multinational joint alert or OFAC designation touching an active vendor relationship. Route every substantive update through the Section 17.2 policy-lifecycle "revision trigger" rather than letting it sit unread in a distribution list, and log the review decision, including a decision that no changes are needed, the same way Part III Section 10.2 calls for logging escalation decisions. An auditable monitoring practice is what turns this chapter from a reading list into an operating control.

Key controls for Part 5

- Name a standing, multi-disciplinary Insider Threat Program Lead and team (HR, Security, Legal, Finance, IT) rather than assembling one only after an incident; benchmark against CISA's POEM framework and the NITTF's six maturity focus areas.
- Treat each hiring-to-offboarding lifecycle stage's control as independent from the next stage's backstop, so a single missed signal does not cascade.
- Deploy the technical indicator baseline (remote-admin tool co-installation, mouse-jiggler software, high-risk VPN egress, KVM signatures) into the same SIEM/UEBA pipeline Part III already runs, mapped to NIST SP 800-53 PS-3 and PS-7.

- Split training by role, run simulated-candidate drills on the same cadence as refresher training, and measure catch rate and time-to-escalation rather than only completion percentage.
- Publish the five core policy documents using a SANS-style structure, and run the program implementation checklist annually, distinct from the per-hire checklist in Appendix C.
- Assign a named owner to monitor FBI, IC3, CISA, State Department, and OFAC advisories on a fixed cadence, and route every substantive update through the policy-revision trigger.

Part VI: Appendices

This closing part converts the handbook into a reference you can reach for during a live hiring decision, not only read once. Appendix A fixes the vocabulary that Parts I through V use throughout, so a term like IAL2 or laptop farm means the same thing whether an HR reviewer or a security analyst is reading it. Appendix B pulls every red flag scattered across the preceding chapters into a single scored table, and Appendix C turns the whole handbook into a copy-ready checklist you can drop into an applicant tracking system or a vendor onboarding runbook. Appendix D points to the full bibliography.

19. Appendix A: Glossary

A shared vocabulary matters more in this handbook than in most, because the threat it addresses sits at the intersection of HR practice, security operations, and international sanctions law, three disciplines that do not normally share a dictionary. An HR reviewer who does not know what an IP-based KVM (keyboard-video-mouse) device is cannot recognize the laptop farm pattern from a shipping-address anomaly, and a security analyst who does not know what “adverse action” means under the Fair Credit Reporting Act (FCRA) can recommend a background-check process that creates legal exposure rather than closing a security gap. The terms below are grouped by the discipline they come from and defined the way they are used in this handbook, not in the abstract; where a term has an authoritative source, the definition links to it.

Threat actors, groups, and frameworks

Term	Definition
DPRK	Democratic People’s Republic of Korea (North Korea), the state whose Reconnaissance General Bureau (RGB) directs the IT worker fraud schemes this handbook is built around.
Facilitator	A person, witting or unwitting, typically U.S.-based, who receives a company-issued laptop, hosts it in a “laptop farm,” relays payment, or otherwise fronts as the visible worker for an overseas operator (DOJ, June 2025).

Term	Definition
Laptop farm	A residence or small office where facilitators receive victim companies' shipped laptops and connect them to remote-access hardware so an overseas operator can work through them, as documented in the Christina Chapman prosecution spanning more than 300 companies.
Lazarus Group	A North Korean state-sponsored threat cluster active since at least 2009, tracked by MITRE ATT&CK as Group G0032 under aliases including HIDDEN COBRA and Diamond Sleet; the broad umbrella name researchers use when a specific North Korean sub-cluster is not distinguished.
APT38	The MITRE ATT&CK-tracked North Korean financial-crime cluster (Group G0082), attributed to the RGB, known for the 2016 Bank of Bangladesh heist and tracked by other vendors under aliases including Bluenoroff and Stardust Chollima.
Famous Chollima	CrowdStrike's designation for the North Korean cluster specializing in IT worker insider threat operations at scale, part of a "Chollima" naming family (a mythical winged horse in Korean folklore) CrowdStrike uses for DPRK-linked actors (CrowdStrike adversary profile).
UNC5267	Google Threat Intelligence Group's (formerly Mandiant's) tracking designation for the DPRK IT worker cluster, documented operating personas across employers in multiple countries simultaneously (Google Cloud, 2024).
AADAPT	Adversarial Actions in Digital Asset Payment Technologies, a MITRE knowledge base of adversary tactics and techniques against cryptocurrency and digital-asset systems, launched July 2025 and modeled on MITRE ATT&CK (MITRE news release ; GitHub).
DPRK RevGen: Domestic Enabler Initiative	A March 2024 joint effort of the U.S. Department of Justice's National Security Division and the FBI's Cyber and Counterintelligence Divisions targeting U.S.-based facilitators of DPRK revenue-generation schemes (DOJ).

Identity, verification, and access

Term	Definition
Identity Assurance Level (IAL)	A three-tier scale from NIST SP 800-63A Revision 4 measuring identity-proofing strength. IAL1 now requires identity evidence, authoritative or credible-source attribute validation, and evidence-ownership verification; it is not self-asserted. IAL2 raises evidence and verification requirements and offers non-biometric, biometric, and digital-evidence pathways. IAL3 requires on-site attended proofing (including a CSP-controlled kiosk with a remote agent) and biometric collection. An organization must assess the complete outcome and pathway, not infer an IAL from a document scan or selfie alone.
Zero trust architecture	A security model, formalized in NIST SP 800-207 , that replaces one-time network perimeter trust with continuous, per-session verification and explicit least-privilege access regardless of the requester's network location.
Least privilege	The practice of granting the minimum access needed for a current task and expanding only on demonstrated, approved need, the default provisioning posture this handbook recommends for every remote or overseas hire.
Mobile device management (MDM)	Enterprise software that enrolls, configures, monitors, and can remotely wipe company-issued devices, the baseline case for remote hardware under NIST SP 800-46 Rev. 2 .
Employer of Record (EOR)	A third-party organization that formally employs a worker on a client company's behalf in a jurisdiction where the client lacks a local entity, adding an independent know-your-customer (KYC) and payroll-compliance layer to an overseas engagement.
Named-individual clause	A contract term requiring a vendor to identify the specific person performing work and to seek written approval and re-verification before substituting anyone else, the primary control against undisclosed facilitator substitution (Section 5.2).
Sensitivity tier	A classification applied to a role based on what its access can reach (source code, production systems, treasury or key-custody functions), used to scale verification depth and access staging (Section 6.3).
Provisional access	Access granted for a defined initial period, typically 30 to 90 days, under tighter logging and a lower threshold for review before it converts to standing access.

Technical indicators and tooling

Term	Definition
IP-based KVM	A keyboard-video-mouse device that streams a physical machine's console over IP, letting a remote operator control a laptop physically located elsewhere, the core hardware enabling the laptop-farm pattern.
Mouse jigglers	Software (Mandiant's reporting names one variant "Caffeine") that simulates activity on an idle workstation to keep multiple job accounts appearing active simultaneously, consistent with one operator holding several concurrent positions (Google Cloud, 2024).
Residential proxy	A proxy service that routes traffic through IP addresses assigned to consumer internet connections, used to mask an operator's true location behind an address that looks like an ordinary home user.
Impossible travel	A detection rule that flags two logins from the same account at locations no legitimate traveler could reach in the elapsed time between them.
SIEM	Security information and event management, the log-aggregation and alerting platform that correlates the technical indicators in Appendix B into a reviewable queue.
UEBA	User and entity behavior analytics, tooling that baselines normal account behavior and flags statistically anomalous deviation, such as a sudden bulk repository clone.
DLP	Data loss prevention, controls that detect or block unusual data egress, such as large transfers to personal cloud storage or messaging apps.
Deepfake	Synthetic audio or video generated or altered by machine learning to impersonate a real person, used in DPRK IT worker interviews to mask a stand-in's true face or voice.
Face-swapping	A specific deepfake technique that overlays one person's face onto another's video feed in real time, the technique the FBI's July 2025 advisory recommends probing for with profile-turn and hand-wave prompts.

Legal, financial, and compliance

Term	Definition
OFAC	The U.S. Treasury's Office of Foreign Assets Control, which administers sanctions programs and maintains the Specially Designated Nationals (SDN) list (sanctions list search tool).
SDN list	The Specially Designated Nationals and Blocked Persons list, a roster of individuals and entities U.S. persons are generally prohibited from transacting with; several DPRK IT worker fronts and facilitators have been formally designated to it.

Term	Definition
Strict liability (sanctions)	A legal standard under which a violation of U.S. sanctions law can attach regardless of the violator's knowledge or intent, meaning a company can face OFAC exposure for engaging an SDN-listed party even unknowingly.
FCRA	The Fair Credit Reporting Act, the U.S. federal law governing background checks run through third-party consumer reporting agencies, requiring disclosure, authorization, and an adverse-action process before declining a candidate on report contents (FTC guidance).
GDPR	The General Data Protection Regulation, the European Union framework that classifies criminal-record data under special processing constraints and gives candidates access and erasure rights over verification data collected about them (EUR-Lex consolidated text; Article 10).
Misclassification	Treating a worker who functions as an employee (integrated into the team, taking day-to-day direction, engaged long-term) as an independent contractor, exposing the company to back taxes, statutory-benefit claims, and director liability in a growing number of jurisdictions.
Phantom worker	A name that remains active in payroll records after the underlying work relationship should have ended, or an unauthorized entry inserted by a facilitator, caught by periodic headcount-to-payroll reconciliation.
Insider threat	A person with authorized access who uses that access, intentionally or through negligence, to cause harm; the Cybersecurity and Infrastructure Security Agency (CISA) structures mitigation around four stages: Define, Detect and Identify, Assess, and Manage (CISA Insider Threat Mitigation Guide).
Termination for cause	Contract or employment termination triggered by a defined breach (security policy violation, sanctions exposure, fraud), typically bypassing the notice period a routine separation would require.

20. Appendix B: Red Flags and Indicators (Summary)

Parts I through III each surface red flags in the context where they appear, a recruitment advisory in Part I, an interview signal in Part II, a post-hire behavior in Part III. Read in sequence, that placement makes sense; read in a live hiring decision, it means a reviewer has to remember which chapter held which indicator. This appendix collects every indicator into one table,

organized by the stage of the relationship where it typically surfaces, so a hiring manager or security analyst can scan a single reference during an active case rather than re-reading three parts.

No single row in this table is proof of fraud on its own. The [FBI/IC3 advisory series](#) and CrowdStrike's Famous Chollima tracking, spanning [more than 320 companies infiltrated in a single year](#), consistently describe a pattern-matching problem, not a single-signal one: a candidate in a different time zone with occasional connectivity issues is not automatically suspect, but a candidate who accumulates rows across three or more categories below has crossed the threshold this handbook recommends for escalation rather than continuation.

Stage	Category	Indicator	Handbook reference
Recruitment	Sourcing	Application arrives through a general freelance marketplace or unsolicited crypto-Discord outreach for a sensitive role	Part II, 3.2
Recruitment	Contact reuse	Phone number, email, or bank routing detail matches a different "unrelated" applicant in the intake log	Part II, 4.3
Interview	Technical	Below-average code quality or unfamiliarity with concepts the claimed seniority level should know cold	Part II, 4.4
Interview	Technical	Heavy reliance on AI coding tools to explain the candidate's own submitted work	Part II, 4.4
Interview	Behavioral	Reluctance to enable camera, or camera enabled only briefly and then disabled	Part II, 4.2, 4.4
Interview	Behavioral	Refuses a second, unscripted video call after passing a scripted first round	Part II, 4.2
Interview	Behavioral	Lip-sync lag, lighting seams, or blink irregularities suggesting a real-time deepfake overlay	Part II, 4.2

Stage	Category	Indicator	Handbook reference
Interview	Behavioral	Cannot answer spontaneous location-specific questions (nearby landmarks, local weather, time-zone math)	Part II, 4.2; Part III, 9.1
Interview	Logistics	Requests shipment of a company laptop to an address that does not match the identification document	Part II, 4.4; Part III, 7.1
Interview	Financial	Payment or banking details that partially match another applicant's record	Part II, 4.4
Post-hire	Network	Login geolocation does not match the shipping address on file, or shifts implausibly between sessions	Part III, 7.1, 9.1
Post-hire	Network	Traffic through commercial VPN or residential-proxy exit nodes, or KVM-over-IP signatures on a device that should be operated locally	Part III, 7.1, 9.1
Post-hire	Network	Working hours map cleanly to a DPRK/China-adjacent time zone rather than the claimed residence	Part III, 7.1, 9.1
Post-hire	Network	Unauthorized remote-administration software (AnyDesk, TeamViewer, RustDesk, Chrome Remote Desktop) appears shortly after provisioning	Part II, 4.5
Post-hire	Access	Requests for elevated privileges shortly after hire, beyond what the assigned role requires	Part III, 9.1
Post-hire	Access	Unusual data access: bulk repository clones, broad document searches unrelated to assigned tasks	Part III, 9.1
Post-hire	Communication	Persistent avoidance of camera-on meetings or voice calls after hire	Part III, 7.3, 9.1

Stage	Category	Indicator	Handbook reference
Post-hire	Communication	Push to move work discussion to unmonitored personal messaging apps	Part III, 7.3, 9.1
Post-hire	Identity	Voice, appearance, or writing style shifts noticeably across sessions	Part III, 9.1
Post-hire	Financial	Mid-engagement request to change payment destination, especially to a new country or a crypto wallet	Part III, 8.2, 9.1
Post-hire	Financial	Bank account name mismatched to identity documents on file	Part III, 8.2, 9.1
Post-hire	Output	Work quality does not match stated experience level, in either direction	Part III, 9.1
Vendor	Contractual	Staffing vendor cannot or will not disclose its own per-contractor identity verification workflow	Part II, 5.1
Vendor	Sanctions	A vendor relationship routes payment through an entity subsequently added to the OFAC SDN list	Part III, 11.1

Treat this table as a scoring input, not a scoring formula: a documented process (Part II, 4.3) that logs which rows were checked and which fired is what turns a subjective hunch into a defensible, auditable decision if a placement is later challenged.

21. Appendix C: Hiring and Vendor Security Checklist

This checklist is built to be copied directly into an applicant tracking system template, a vendor onboarding runbook, or a hiring-manager job aid. Each phase lists the minimum actions Parts II and III establish as controls, not aspirational best practice; skipping an item should be a documented, named exception, not a silent gap. Phase ownership follows the split the README sets out: HR and hiring managers own Pre-Posting through Offer, security and IT own Device Provisioning and Ongoing Monitoring, and legal or compliance signs off on Vendor Contract and Termination.

Pre-Posting

- ☐ Role sensitivity tier assigned (Tier 1/2/3, Section 6.3) before the requisition opens
- ☐ Posting channel confirmed as owned (careers page/ATS) or a named, vetted recruiting partner
- ☐ High-risk sourcing (general freelance marketplaces, unsolicited crypto job boards) excluded for Tier 2/3 roles, or a documented compensating-control decision is on file

Sourcing and Application Intake

- ☐ Application routed into a single system of record (no scattered email-only applications)
- ☐ Duplicate-detection pass run against phone number, email, and payment details before scheduling an interview
- ☐ Recruiter or platform account identity verified through a channel the candidate did not supply

Interview

- ☐ Live, camera-on video required for every round; no virtual backgrounds obscuring the frame
- ☐ At least one round includes spontaneous, unscripted questions and a location-verification prompt (profile turn, hand wave, point camera at surroundings)
- ☐ Identity proofing provider records a complete NIST IAL2 outcome: sufficient evidence, validation sources, verification pathway, proofing type, exceptions, and result; a document scan plus selfie alone is not treated as the definition
- ☐ Name screened against the OFAC SDN list and equivalent sanctions lists
- ☐ Technical assessment conducted live and proctored, not solely asynchronous
- ☐ Interviewer notes logged in the ATS, not personal messages or memory
- ☐ Red-flag table (Appendix B) reviewed by the panel before an offer decision

Background and Reference Verification

- ☐ Jurisdiction-appropriate legal constraints confirmed (FCRA disclosure/authorization in the U.S.; GDPR lawful basis and proportionality assessment in the EEA)
- ☐ Education verified through an institutional service, not a candidate-supplied document
- ☐ Employment references called at the institution's published main number, not a number the candidate or reference supplied

Offer and Onboarding

- ☐ Sensitivity-tier verification floor met before an offer is extended (Section 6.3 table)
- ☐ Device shipment address matches the verified identification document; deviation escalated, not accommodated
- ☐ MDM-managed hardware issued for any role touching source code, customer data, or funds
- ☐ Hardware-bound MFA (FIDO2 key or platform authenticator) enrolled to the shipped device
- ☐ Least-privilege, provisional access granted (30-90 day review window); no standing elevated access on day one

Vendor and Contractor Selection

- ☐ Vendor discloses its own per-contractor identity-verification workflow, subject to audit
- ☐ Contract includes a named-individual, no-substitution clause with re-verification on any personnel change
- ☐ Contract prohibits connecting client-accessed equipment through third-party KVM or remote-administration hardware
- ☐ Contract includes audit and monitoring rights over system usage and activity logs
- ☐ Contract includes immediate, notice-bypassing termination for cause tied to security policy violation or suspected fraud

Ongoing Monitoring

- ☐ Conditional access alerts configured for geolocation/shipping-address mismatch, VPN/proxy egress, and concurrent-session anomalies
- ☐ Unannounced video verification scheduled on a cadence proportional to access sensitivity (monthly for privileged roles, quarterly otherwise)
- ☐ Payment destination re-screened against sanctions lists on a recurring basis, not only at contract signing
- ☐ Headcount reconciled against payroll on a schedule to catch phantom or unauthorized entries
- ☐ Named escalation owner defined at the intersection of HR, security, and legal for hiring-and-vendor-linked concerns

Offboarding and Termination

- ☐ Contract substitution treated as a new-hire event: re-verification and provisional access reset, not a lifecycle no-op
- ☐ Sanctions hit or law-enforcement inquiry triggers emergency offboarding, bypassing standard notice periods
- ☐ Device retrieval, remote-wipe confirmation, and credential rotation scheduled explicitly for non-co-located personnel
- ☐ Escalation decision, including a decision not to act, documented for future pattern correlation

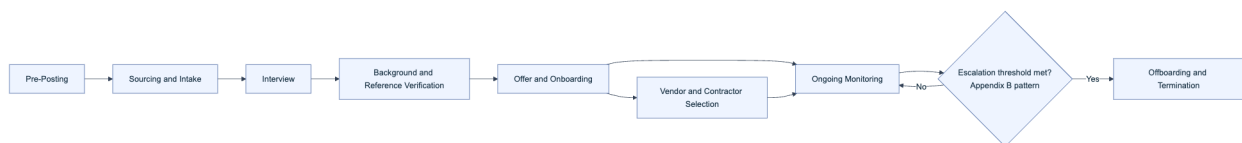


Figure 9. The checklist phases as sequential gates. Ongoing Monitoring is a loop, not a terminal step: every phase after onboarding feeds back into it until either the engagement ends normally or an escalation triggers Offboarding and Termination.

22. Appendix D: References, Advisories, and Further Reading

Every source cited across Parts I through VI, government advisories, standards documents, incident post-mortems, and vendor threat-intelligence reporting, is collected in `references.md`, grouped into Standards and Frameworks, Incidents and Case Studies, Tools, and Further Reading, per the **series conventions**. Use it as the citation index when you need the primary source behind a claim in this handbook, when a link in the body has gone stale, or when you are building an internal policy document and need to cite the underlying FBI, CISA, IC3, DOJ, OFAC, or NIST publication directly rather than this handbook's summary of it. Advisories in this space update on a rolling basis, so treat `references.md` as the starting point for a fresh check against the issuing agency's own site rather than a permanently current mirror.

Key controls for Part 6

- Use Appendix A's terms consistently across HR, security, and legal documentation so a single incident report reads the same way to every function that touches it.
- Run Appendix B's consolidated indicator table as a scored review, not a single-flag veto; escalate on clustering across categories.
- Lift Appendix C directly into your ATS or vendor-onboarding tooling as a gating checklist, with named exceptions logged rather than silently skipped.
- Treat `references.md` (Appendix D) as the live citation index and re-verify time-sensitive advisories against the issuing agency before relying on a cached figure.

Appendix C: References and Further Reading

The sources below are cited throughout this handbook and are grouped here by type for quick lookup.

Standards and Frameworks

- NIST SP 800-207, Zero Trust Architecture
- NIST SP 800-46 Rev. 2, Guide to Enterprise Telework, Remote Access, and BYOD Security
- NIST Special Publication 800-53 Revision 5
- NIST SP 800-61 Revision 3, “Incident Response Recommendations and Considerations for Cybersecurity Risk Management,” April 2025
- NIST Special Publication 800-63A, Digital Identity Guidelines
- NIST Special Publication 800-63 Digital Identity Guidelines project page
- EUR-Lex consolidated text of the GDPR
- GDPR Article 10
- MITRE ATT&CK
- MITRE ATT&CK Group G0032
- MITRE ATT&CK Group G0082
- AADAPT cybersecurity framework for cryptocurrency
- AADAPT GitHub repository
- MITRE news release introducing the AADAPT framework
- CISA, “Insider Threat Mitigation Guide”
- CISA, “Assembling a Multi-Disciplinary Insider Threat Management Team”
- NCSC Insider Threat Program Maturity Framework
- National Insider Threat Task Force (NITTF)
- SANS Institute Security Policy Project
- OFAC North Korea Sanctions Program
- UN Security Council 1718 Sanctions Committee resolutions

Incidents and Case Studies

- KnowBe4, “How a North Korean Fake IT Worker Tried to Infiltrate Us,” July 2024
- KnowBe4, North Korean fake IT worker FAQ
- KnowBe4 blog
- Kraken, “How We Identified a North Korean Hacker”

- SecurityWeek, “KnowBe4 Hires Fake North Korean IT Worker, Catches New Employee Planting Malware”
- The Record, Christina Chapman “laptop farm” case
- BleepingComputer, US woman sentenced for running a laptop farm for North Koreans
- DOJ, “Justice Department Announces Coordinated Nationwide Actions to Combat North Korean Remote IT Worker Fraud”
- DOJ, multi-defendant indictment covering 64 U.S. companies
- Treasury OFAC designations of July 2024 on DPRK IT worker facilitator networks (GlobalSecurity.org)
- ZachXBT

Tools and Documentation

- Cybersecurity and Infrastructure Security Agency (CISA)
- CISA Advisory AA21-048A
- CISA/FBI/Treasury Advisory AA22-108A
- Internet Crime Complaint Center (IC3)
- FBI IC3 PSA I-051622-PSA, May 2022
- FBI/IC3 follow-up guidance, PSA231018
- IC3 PSA250123, North Korean IT Workers Conducting Data Extortion
- IC3 PSA250723-4, North Korean IT Worker Threats to U.S. Businesses
- State Department, “Guidance on the Democratic People’s Republic of Korea Information Technology Workers,” May 2022
- State Department, “Alert to Countries, Companies, and Other Entities Regarding North Korean IT Workers,” 2026
- May 2022 State/Treasury/FBI joint advisory (mirrored copy)
- May 2022 US Treasury, State Department, and FBI advisory (OFAC document)
- OFAC sanctions list search tool
- Department of Justice press releases
- US Treasury press releases
- Rewards for Justice DPRK IT worker program
- Google Cloud/Mandiant, “Staying a Step Ahead: Mitigating the DPRK IT Worker Threat”
- Google Threat Intelligence Group, DPRK IT workers expanding scope and scale, 2025
- Google Cloud/Mandiant, M-Trends 2026
- CrowdStrike adversary profile: Famous Chollima
- CrowdStrike Global Threat Report
- CrowdStrike 2025 Global Threat Report findings blog
- Unit 42, “Contagious Interview: DPRK Threat Actors Lure Tech Industry Job Seekers,” 2024
- Elastic Security Labs

- Microsoft Threat Intelligence, “Jasper Sleet: North Korean remote IT workers’ evolving tactics to infiltrate organizations”
- Spur research on remote worker fraud detection
- IPinfo, impossible travel detection and IP data accuracy
- Center for Development of Security Excellence (CDSE)

Further Reading

- ASIS International, “Recruitment Red Flags: Spotting DPRK IT Remote Workers”
- FTC guidance on using consumer reports for employment decisions
- Skadden analysis of North Korean remote IT worker risk, June 2026
- Toku’s employer vs. contractor misclassification risk analysis in crypto
- National Student Clearinghouse’s DegreeVerify